

Combining Cyber Security Intelligence to Refine Automotive Cyber Threats

FLORIAN SOMMER and MONA GIERL, Karlsruhe University of Applied Sciences, Karlsruhe, Germany

REINER KRIESTEN, Karlsruhe University of Applied Sciences, Karlsruhe, Germany

FRANK KARGL, Ulm University, Ulm, Germany

ERIC SAX, Karlsruhe Institute of Technology, Karlsruhe, Germany

Modern vehicles increasingly rely on electronics, software, and communication technologies (cyber space) to perform their driving task. Over-The-Air (OTA) connectivity further extends the cyber space by creating remote access entry points. Accordingly, the vehicle is exposed to security attacks that are able to impact road safety. A profound understanding of security attacks, vulnerabilities, and mitigations is necessary to protect vehicles against cyber threats. While automotive threat descriptions, such as in UN R155, are still abstract, this creates a risk that potential vulnerabilities are overlooked and the vehicle is not secured against them. So far, there is no common understanding of the relationship of automotive attacks, the concrete vulnerabilities they exploit, and security mechanisms that would protect the system against these attacks. In this article, we aim at closing this gap by creating a mapping between UN R155, Microsoft STRIDE classification, Common Attack Pattern Enumeration and Classification (CAPEC), and Common Weakness Enumeration (CWE). In this way, already existing detailed knowledge of attacks, vulnerabilities, and mitigations is combined and linked to the automotive domain. In practice, this refines the list of UN R155 threats and therefore supports vehicle manufacturers, suppliers, and approval authorities to meet and assess the requirements for vehicle development in terms of cybersecurity. Overall, 204 mappings between UN threats, STRIDE, CAPEC attack patterns, and CWE weaknesses were created. We validated these mappings by applying our Automotive Attack Database (AAD) that consists of 361 real-world attacks on vehicles. Furthermore, 25 additional attack patterns were defined based on automotive-related attacks.

CCS Concepts: • **Security and privacy**; • **Applied computing** → **Transportation**; • **Computer systems organization** → *Embedded and cyber-physical systems*;

Additional Key Words and Phrases: Automotive security, taxonomies, attacks, vulnerabilities, mitigations

F. Sommer and M. Gierl contributed equally to this research.

This work was developed in the project SecForCARS-SAVE (reference no. 16KIS0796), funded by the German Ministry of Education and Research (BMBF). Additional funding was provided by GTÜ Gesellschaft für technische Überwachung mbH in Stuttgart, Germany.

Authors' addresses: F. Sommer, M. Gierl, and R. Kriesten, Karlsruhe University of Applied Sciences, Moltkestraße 30, Karlsruhe, Baden-Württemberg, 76133, Germany; e-mails: {florian.sommer, mona.gierl, reiner.kriesten}@h-ka.de; F. Kargl, Ulm University, Helmholtzstraße 16, Ulm, Baden-Württemberg, 89081, Germany; e-mail: frank.kargl@uni-ulm.de; E. Sax, Karlsruhe Institute of Technology, Kaiserstraße 12, Karlsruhe, Baden-Württemberg, 76131, Germany.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from [permissions@acm.org](https://doi.org/10.1145/3644075).

© 2024 Copyright held by the owner/author(s). Publication rights licensed to ACM.

ACM 2471-2566/2024/03-ART16

<https://doi.org/10.1145/3644075>

ACM Reference Format:

Florian Sommer, Mona Gierl, Reiner Kriesten, Frank Kargl, and Eric Sax. 2024. Combining Cyber Security Intelligence to Refine Automotive Cyber Threats. *ACM Trans. Priv. Sec.* 27, 2, Article 16 (March 2024), 34 pages. <https://doi.org/10.1145/3644075>

1 INTRODUCTION

The steady increase of electrical and **Information Technology (IT)** components in vehicles in recent years has led to a growing interest among vehicle manufacturers in protecting these components against cyber attacks. As a reference, the number of **Electronic Control Units (ECUs)** has grown from around 20 to more than 100 over the past 20 years [39]. Further, today's vehicles approximately have 100 million lines of code and are expected to have 300 million lines of code by 2030 [7]. In autonomous driving in particular, cyber attacks can affect the health of vehicle occupants as well as surrounding traffic, as these vehicles operate in an automated manner. The extent and feasibility of such attacks has been demonstrated by several researchers and attackers in the past, as shown in a survey in 2019 [61]. As a result, the industry identified the need for a process that takes cybersecurity into account during development and over the lifecycle of a vehicle. For this reason, UN Regulation No. 155 (UN R155) on cybersecurity and the **Cybersecurity Management System (CSMS)** [69] and ISO/SAE 21434:2021 (Road Vehicles–Cybersecurity engineering) [28] were published at the beginning of 2021. Both documents describe a continuous cybersecurity-specific development process and require vehicle manufacturers to comply with it. The focus is on conducting a **Threat Analysis and Risk Assessment (TARA)** and developing security concepts to protect a vehicle. Thus, the system is analyzed for potential threats that are assessed and prioritized for their risk. Based on these results, security concepts and security mechanisms (mitigations) are derived and implemented in a vehicle. Although the standards describe this process in detail, they largely leave open which methods are to be used for a Threat Analysis and Risk Assessment (TARA) and which mitigations should be implemented. Furthermore, the area of security testing is described rather superficially. Here, functional tests, penetration testing, fuzzing, and vulnerability scanning are mentioned as test methods. The latter are usually carried out by external service providers and can only be used late in development, when a vehicle or its subsystems have already been fully developed. Particularly regarding approval procedures (e.g., type approval), this creates the difficulty of tracking which threats have been secured and tested by the manufacturer. A detailed and systematic description of security attacks, vulnerabilities, and mitigations would be necessary for both security testing and the approval process.

Problem. Due to the high degree of interaction between many different technological components, vehicles combine several domains (telecommunication, IT, etc.). Thus, security attacks on these components can differ greatly across its various subdomains. UN R155 [69] provides a list of threats and associates mitigations that vehicle manufacturers should address. However, these are described at a high level of abstraction. This makes it difficult to have a uniform understanding of the relationship of attacks, concrete vulnerabilities they exploit, and security mechanisms that would protect the system against these attacks. This creates a risk that potential attacks and vulnerabilities are overlooked and vehicles are not secured against them.

Solution. To describe the relationship between automotive-related attack techniques, vulnerabilities, and mitigations, we propose a mapping between UN R155 and other cybersecurity taxonomies. In particular, we use Microsoft's STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) [32] classification and the **Common Attack Pattern Enumeration and Classification (CAPEC)** [65] to map automotive threats of UN R155 to concrete attack techniques. Since UN R155 and CAPEC both provide mitigation strategies for

their threats/attacks, this enables us to extract suitable mitigations for each mapping. Furthermore, we use the **Common Weakness Enumeration (CWE)** [66] to describe vulnerabilities that are associated with mapped attacks and threats. This mapping approach combines related aspects of the individual taxonomies. In this way, a relationship between attacks, vulnerabilities, and mitigations for different domains emerges, which enables the application of existing cybersecurity knowledge to the automotive domain.

Contribution. In this article, we present a mapping between UN R155, STRIDE, CAPEC, and CWE. For each of the 31 UN R155 threats, we assign at least 1 of the 59 CAPEC *Meta Attack Patterns*. We further classify this mapping according to STRIDE and at least 1 technical domain (*Software, Hardware, Communication*). For each mapping, related weaknesses are outlined by providing suitable CWEs and mitigations are extracted from UN R155 and CAPEC. To validate and refine our approach, we apply our **Automotive Attack Database (AAD)** [60] for each mapping. This database contains a collection of real-world security attacks on vehicles. As of June 2023, 361 attacks consisting of 621 attack steps are included. As a result, we were able to create 204 mappings from which 95 have been validated by our AAD. Based on the AAD, we further define 25 additional attack patterns that are currently not covered by CAPEC. Overall, these results provide concrete attack patterns, weaknesses/vulnerabilities, and suitable mitigation strategies for each automotive threat of the UN R155 and provides a common understanding of the relationship between these items. This supports vehicle manufacturers, suppliers, and regulatory authorities to meet requirements the UN R155 and ISO/SAE 21434 demand for vehicle development and type approval when it comes to cybersecurity.

This work is structured as follows. In Section 2, we introduce automotive security fundamentals and common attack taxonomies—in particular, ISO/SAE 21434, UN R155, Common Attack Pattern Enumeration and Classification (CAPEC), and Common Weakness Enumeration (CWE) are highlighted. Section 3 addresses related work and the differentiation from our approach. Section 4 presents our approach and mapping procedure, whereas Section 5 explains the results of the mapping in detail. In Section 6, the results and their implications are discussed. Finally, in Section 7, we give a conclusion and an outlook on future work.

2 BACKGROUND

Cyber attacks aim at exploiting one or more weaknesses (listed by CWE) or vulnerabilities (listed by **Common Vulnerabilities and Exposures Enumeration (CVE)** of a system and target asset loss. To carry out a successful attack, various attack techniques are used by attackers. To understand how adversaries exploit weaknesses (flaws, faults, bugs, or other errors), CAPEC provides a list of common adversarial attack patterns. In this section, the details of CAPEC and CWE are explained. First, fundamentals of automotive security and related standards and taxonomies are presented.

2.1 ISO/SAE 21434 Road Vehicles: Cybersecurity Engineering

Protecting vehicles from cyber threats and their respective risks is a continuous task throughout the vehicle lifecycle. In this regard, ISO/SAE 21434 [28] describes cybersecurity engineering principles of electrical and electronic systems. ISO/SAE 21434 was developed according to the safety process of ISO 26262 [27] and defines terminologies, objectives, requirements, and guidelines across the automotive supply chain to drive a common consensus on key cybersecurity issues. The application of the standard for vehicle development is covered in the literature [13, 37]. In accordance with the V-model, this standard comprises requirements engineering, design, specification, implementation, testing, and operation. Overall, a risk-based approach is proposed, whereas TARA methods are suggested to be used for risk assessment and to derive appropriate countermeasures.

The TARA in itself is not bound to a specific methodology. A collection of potential automotive analysis methods is listed in SAE J3061 [58] as well as in the work of Luo et al. [36]. Threat assessment as part of the initial TARA phase provides a basis for security design and requirements engineering. Furthermore, it represents a foundation for subsequent test and approval activities. For empirical data, all of these activities rely, for example, on known vulnerabilities, attack databases, taxonomies, and therefore knowledge about cybersecurity issues. The challenge here is to update and maintain knowledge so that respective databases are aware of current attack techniques and exploited vulnerabilities. In the Information Technology (IT) domain, for example, CAPEC, Common Vulnerabilities and Exposures Enumeration (CVE), CWE, and the MITRE ATT&CK framework [67] exist for this purpose. In particular, the CVE catalog lists publicly disclosed product or system vulnerabilities and also contains automotive-specific entries (e.g., CVE-2019-12797). However, considering connected vehicles, a community-maintained common knowledge base for automotive security threats is still missing.

2.2 UN R155 Vehicle Regulation on Cybersecurity

For a vehicle to be approved for road admission, it has to meet regulatory standards and specifications. To reduce international trade barriers and to harmonize existing regulations, the United Nations Economic Commission for Europe (UN/ECE) World Forum for Harmonization of Vehicle Regulations (WP.29) is constantly working on new regulations for type approval. In this context, UN R155 [69] for cybersecurity and UN R156 [70] for software updates were published in 2021. In particular, UN R155 is the first vehicle regulation dealing with uniform provisions concerning approval of vehicles with regard to cybersecurity and CSMS. According to UN R155, a CSMS is a “systematic risk-based approach defining organisational processes, responsibilities and governance to treat risk associated with cyber threats to vehicles and protect them from cyber-attacks” [69, p. 4]. In this regard, the requirements distinguish two areas: organizational processes concerning the implementation of a Cybersecurity Management System (CSMS) and requirements for the vehicle type and its components. Thus, a manufacturer is responsible for having a management system in place that monitors and treats respective cyber risks throughout the entire lifecycle but also that a vehicle is equipped with appropriate security countermeasures. In this context, a TARA is explicitly required from a manufacturer. As a reference, UN R155 provides a list of common threat categories in its annex and assigns mitigations to them. A total of 31 threats and 23 mitigations are listed and must be taken into account according to Paragraph 7.3.4 of UN R155. Overall, the regulation does not name explicit countermeasures—instead, the associated interpretation document [74] proposes to use vulnerability and threat sharing platforms and experiences from previous attacks as a source for risk identification.

2.3 Common Attack Pattern Enumeration and Classification

CAPEC [65] is a classification scheme for known attack patterns provided by the MITRE Corporation. It includes a public catalog of attack patterns, which should help the security community understand attack procedures attackers use to compromise a system. In other words, CAPEC attack patterns describe how weaknesses can be exploited by adversaries. Currently (Version 3.7), CAPEC consists of 546 hierarchically ordered attack patterns. At the highest level of hierarchy, CAPEC distinguishes two main views: *CAPEC-1000: Mechanisms of Attack* and *CAPEC-3000: Domains of Attack*. In addition, further views to external taxonomies are offered but are not discussed here. *Mechanisms of Attack* classifies attack patterns according to nine subcategories, whereas *Domains of Attack* divides attack patterns to six subcategories as shown in Table 1.

Each category is associated with a set of *Meta Attack Patterns*. These represent abstract descriptions of a particular attack method at a high level and are independent of technologies. *Meta Attack*

Table 1. Two CAPEC Main Views (V) and Their Categories (C)

V	Mechanisms of Attack	Domains of Attack
C	CAPEC-156: Engage in Deceptive Interactions	CAPEC-513: Software
	CAPEC-210: Abuse Existing Functionality	CAPEC-515: Hardware
	CAPEC-255: Manipulate Data Structures	CAPEC-512: Communications
	CAPEC-262: Manipulate System Resources	CAPEC-437: Supply Chains
	CAPEC-152: Inject Unexpected Item	CAPEC-403: Social Engineering
	CAPEC-223: Employ Probabilistic Techniques	CAPEC-514: Physical Security
	CAPEC-172: Manipulate Timing and State	
	CAPEC-118: Collect and Analyze Information	
	CAPEC-225: Subvert Access Control	

The *Mechanisms of Attack* view consists of nine attack mechanisms/techniques, and the *Domains of Attack* view consists of six system/attack domains.

Patterns are refined by either a *Standard Attack Pattern* or *Detailed Attack Pattern*. *Standard Attack Patterns* represent specific attack techniques or steps (e.g., CAPEC-242: *Code Injection*), whereas *Detailed Attack Patterns* refer to a specific technology. This hierarchical structure allows attack techniques to be represented in different levels of detail. Overall, an attack pattern provides different information about an attack technique. In addition to a description of the pattern, information about the execution of an attack, preconditions that must be met, likelihood and severity, and potential effects of an attack are provided. Furthermore, potential mitigations to prevent the attack and weaknesses exploited by that attack are described. Affected weaknesses correspond to the CWE taxonomy. In addition, mappings to other attack-related taxonomies, such as the **Open Web Application Security Project (OWASP)** or MITRE ATT&CK, are provided.

2.4 Common Weakness Enumeration

CWE [66] is a classification scheme provided by the MITRE Corporation for weaknesses of software and hardware systems. Weaknesses are arranged hierarchically, with the top hierarchy level subdivided by different views (e.g., only software-related or only hardware-related weaknesses). All weaknesses are included in the *CWE-1000: Research Concepts* view, which currently comprises 926 different CWEs. Due to its completeness, we refer to the *CWE-1000: Research Concepts* view for further analysis. So-called *Pillar* weaknesses are assigned to this view on the top level, since they have the highest degree of abstraction. Each *Pillar* weakness is associated with a hierarchical tree similar to the CAPEC hierarchy. Included CWEs can be divided into the categories *Class*, *Base*, and *Variant*. Class weaknesses represent an abstract and technology-independent grouping of weaknesses. A Base weakness is more specific than a Class weakness, but more general than a Variant weakness. Variant weaknesses can be assigned to specific technologies and systems. They thus represent the most detailed concretization of CWEs. Overall, CWE provides detailed information for each weakness. First, there is a weakness description and a mapping to other CWEs (e.g., peer or child CWEs). Depending on the CWE category, information on affected technologies and platforms as well as detailed examples are given. Besides, related CAPEC attack patterns and further vulnerability taxonomies are referenced, also including CVE entries from the **National Vulnerability Database (NVD)**.

3 RELATED WORK

In this work, security-related taxonomies and classification schemes are linked with the automotive domain. In particular, we establish a mapping among UN R155, STRIDE, CAPEC, and CWE. This results in a series of interrelated attacks, vulnerabilities, and mitigations from different

taxonomies. Similar automotive taxonomies can be found in literature. Thing and Wu [68] present a taxonomy for security attacks and possible defenses for autonomous vehicles. Attacks are classified into five categories: *Attacker*, *Attack vector*, *Target*, *Motive*, and *Potential consequence*. The *Attack vector* category is particularly interesting, as it is an indicator for attack techniques. Here, a distinction is made between *Physical access* and *Remote access*, with both being assigned different attack techniques, such as *Packet fuzzing*. Similarly, the four categories *Preventive defense*, *Passive defense*, *Active defense*, and *Collaborative defense* are proposed as defenses to protect autonomous vehicles. Pekaric et al. [51] present a taxonomy and a classification of attack techniques based on a systematic literature review. A total of 48 attack techniques from scientific publications between 2014 and 2019 are considered. This taxonomy uses the *CAPEC-1000: Mechanisms of Attack* view and distinguishes five categories: *AUTOSAR Layers*, *attack domains*, *information security principles*, *attack surfaces*, and *attacker profile*. Chowdhury et al. [9] present a survey of real-world attacks on autonomous vehicles and associated countermeasures. The authors classify attacks into categories, such as *Violated security*, *Impact*, *Exposed vulnerability*, or *Type of Attacks*. The latter distinguishes attack mechanisms, such as *Malware*, *Jamming*, *Spoofing*, or *Sybil*. In addition, mitigations are highlighted for each attack. Aliwa et al. [2] present a survey of attacks on in-vehicle communications systems and possible countermeasures. In particular, they focus on the **Controller Area Network (CAN)** bus and its protocols. The authors list attacks in which attackers accessed Controller Area Network (CAN) via various entry points to a vehicle (e.g., **On-Board Diagnostics (OBD)** interface, or telematics). Attack techniques, such as *bus fuzzing*, *denial of service*, *frame falsifying*, or *injections attacks*, were executed. Subsequently, countermeasures, such as encryption or authentication, are discussed. In detail, the authors discuss the **Intrusion Detection System (IDS)** and present proposed approaches from the literature. Rumez et al. [56] compare the conventional signal-oriented communication of in-vehicle networks with emerging service-oriented architectures and provide a survey about the arising security implications. They focus on firewalls, Intrusion Detection System (IDS), and access control and discuss their applicability for future automotive network architectures. Compared to these works, our approach uses already established, widely applied security taxonomies from adjacent domains. By combining them with automotive-related taxonomies, a common knowledge base for attacks, vulnerabilities, and mitigations is created.

In 2019, we published our own survey [61] on cyber attacks on vehicles to obtain an overview of existing attacks and to derive information that can be used for TARA and security testing. This resulted in AAD [60] as of June 2023 consisting of a total of 361 attacks (composed of 621 attack steps). These attacks originate from various public sources, such as scientific publications, trade journals, press articles, or vulnerability databases. Based on the collected data, we developed a taxonomy and classified all attacks in a uniform manner. Within the taxonomy, specific details of respective attack steps are described (affected assets, violated security properties, attack paths, consequences, risk ratings, etc.). Of particular interest for this work are the categories *Vulnerability* and *Attack Class*. To describe vulnerabilities, we use the CWE classification. The *Attack Class* category describes the attack technique used and consists of three hierarchical levels. On the first level, the Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege (STRIDE) classification is used. The approach of this article can be seen as an extension of our attack taxonomy, especially regarding the *Vulnerability* and *Attack Class* categories.

The use of STRIDE or CAPEC to describe threats in the automotive domain has been proposed by several works. As mentioned previously, Pekaric et al. [51] use the *CAPEC-1000: Mechanisms of Attack* to classify their attack techniques. Yan et al. [76] propose STRIDE for modeling threats to vehicular cloud computing in VANETs (Vehicular Ad Hoc Networks) and mention CAPEC as a possible alternative. Ouchani and Khaled [49] use CAPEC to describe various threats to a

cyber-physical system. In particular, patterns from the CAPEC *Domains Software* and *Communications* are used to model threats as activity diagrams. These are used in a modeling framework to model the cyber-physical system, possible attacks, and countermeasures. The authors demonstrate their approach using automobiles as an example. Our approach partially builds on these methods and uses existing taxonomies (CAPEC, STRIDE, CWE) to describe attacks, vulnerabilities, and possible mitigations and map them to each other in the automotive context.

The mapping of different security taxonomies and classification schemes is also found within the literature. Honkaranta et al. [23] present a mapping of Microsoft's STRIDE classification scheme to the CWE Top 25 as well as Open Web Application Security Project (OWASP) Top 10, representing the 25 and 10 most common weaknesses/threats of the respective taxonomy. Similarly, Yuan et al. [77] present a tool where STRIDE is mapped to CAPEC attack patterns to support the consideration of security in the software development process. Our approach differs from these methods since we map these taxonomies to one another with the goal of refining automotive threat knowledge. For example, we assign STRIDE categories to CAPEC, CWE, and UN R155 threats individually. Afterward, we map UN R155 threats to CAPEC attack patterns and their linked CWE weaknesses based on common STRIDE categories.

4 APPROACH

To align knowledge of attack techniques, vulnerabilities, and mitigations from different domains with the automotive domain, we present a mapping between attack patterns of CAPEC, weaknesses of CWE, and threats and mitigation of UN R155. As of today, UN R155 is the first cybersecurity regulation for vehicle manufacturers and suppliers (see Section 2.2). The regulation lists a total of 31 cyber threats to be considered during development. For each threat, suitable mitigations are linked to prevent these threats. Since these threats and mitigations are expressed at a high abstraction level, we aim to refine them by linking UN threats and CAPEC attack patterns. As described in Section 2, CAPEC patterns provide detailed information about different attack techniques, related weaknesses (CWEs), and possible mitigation strategies. Additionally, CAPEC and CWE already have references to other taxonomies or databases, such as MITRE ATT&CK [67], OWASP, and the National Vulnerability Database (NVD). By mapping these taxonomies, we create a chain of relationships between attack techniques, vulnerabilities, and mitigations of individual taxonomies and domains. In Figure 1, these relationships are illustrated. The coupling of the different taxonomies is based on the 31 threats of UN R155 and 59 CAPEC *Meta Attack Patterns*. At least 1 CAPEC meta pattern is assigned to a UN threat. Since mitigations are listed by both the UN R155 and CAPEC attack patterns, coupling them automatically creates a link between their mitigation strategies. CAPEC already has a link to CWE, thus our mapping additionally creates a link between UN threats, CWEs, and their referenced taxonomies. Subsequently, considering our AAD, we are further able to validate and refine the mapping with real-world attacks on vehicles. Overall, this results in a relationship between attacks/threats, vulnerabilities/weaknesses, and mitigations for taxonomies of different domains (automotive, IT, etc.). To carry out that mapping, we follow a defined process, which is illustrated in Figure 2 and graphically summarizes our approach with additional insights into each step of the process.

In step ①, we classify each UN threat and CAPEC meta pattern into attack categories by assigning them with at least one of the STRIDE categories. For CAPEC, this assignment is based on the pattern description and violated security properties specified as *Consequence*. For UN threats, this mapping is based on the threat description and its associated examples. We further assign at least one of the technical domains *Software*, *Hardware*, or *Communications* (based on the CAPEC-3000 Domain View, see Section 2). For CAPEC, the domains are already assigned for most meta patterns. Regarding the UN threats, this assignment is based on the *High level* descriptions given in UN R155

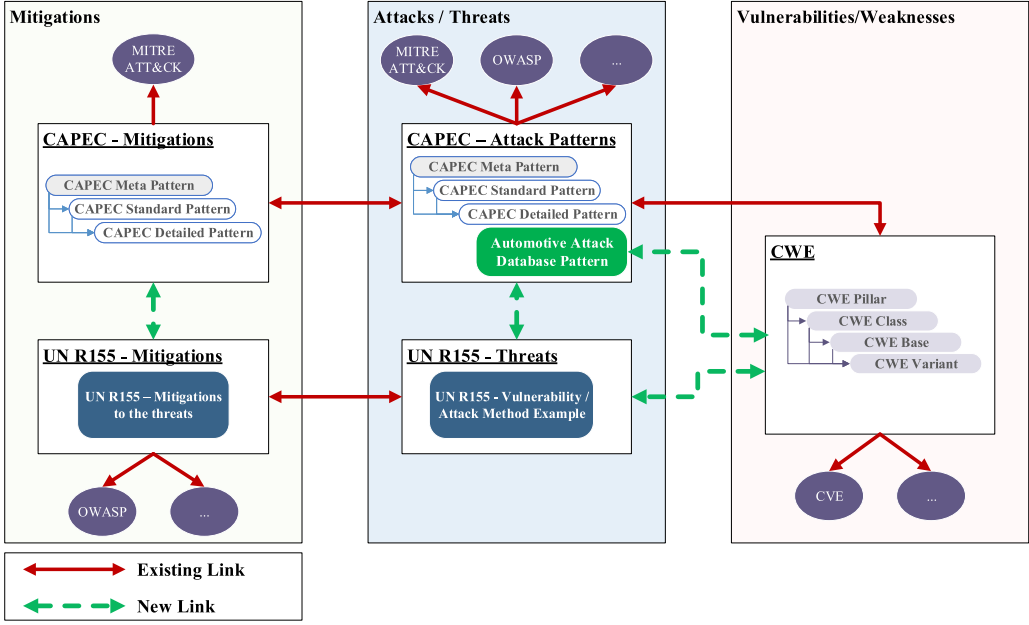


Fig. 1. Relationship between attacks/threats, vulnerabilities/weaknesses, and mitigations. Red arrows highlight existing links. Green arrows highlight new resulting relationships from mapping threats of UN R155 to attack patterns of CAPEC and weaknesses of CWE. This further creates a link to already linked taxonomies or databases, such as MITRE ATT&CK.

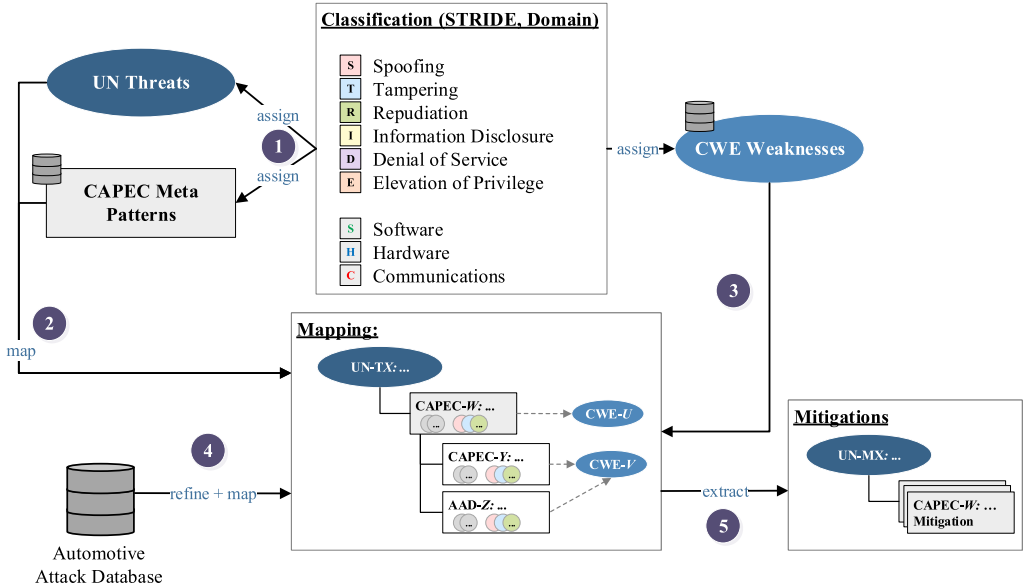


Fig. 2. Process of mapping UN threats and CAPEC *Meta Attack Patterns* as well as the following extension through CWE weaknesses and refinement through our attack database [60].

for each threat (e.g., 4.3.2 *Threats to vehicles regarding their communications channels* [69]). This first step is necessary to set UN threats and CAPEC patterns into a common context (e.g., *Tampering of Hardware*), which makes it easier to map them in the next step.

In step ②, we map UN threats and CAPEC meta patterns. For this purpose, we analyze their descriptions for common attack/threat characteristics. Moreover, we only map them in case of mutual technical domains and STRIDE categories. It should be noted that a UN threat can have multiple CAPEC meta patterns assigned, since most UN threats are described in an abstract manner. As a result, the mapping may not always be unambiguous. However, by using assigned STRIDE categories and technical domains, we narrow down our mapping and largely eliminate ambiguities.

In step ③, we consider CWEs, which are already linked to the CAPEC meta patterns. We use the same procedure as described in the first step by assigning at least one technical domain and STRIDE category to CWE weaknesses. We add resulting CWEs to our mapping by only considering CWEs which share common domains and STRIDE categories with related CAPEC meta patterns and UN threats. It should be noted that not all CAPEC patterns have a CWE link. For this case, we look at sub patterns of the respective meta pattern to assign matching CWEs (based on the assumption that a meta pattern also includes weaknesses of its sub patterns). In case none of the sub patterns has a link, we assigned a CWE ourselves. Thus, for each mapping there is a relationship between UN threat, CAPEC pattern, and CWE.

In step ④, we validate and extend our mapping by matching attack steps from our AAD [60] with meta patterns and UN threats. This database is classified according to the taxonomy described in Section 3 [61]. In particular, the taxonomy categories *Attack Class* and *Vulnerability* are relevant. The *Vulnerability* category has been classified according to CWE when it was published in 2019. Similarly, *Attack Class* is already classified by STRIDE and describes the used attack techniques. To validate our mappings, we check whether an attack step from the AAD corresponds to a UN threat, mapped CAPEC pattern, and related CWE. We performed this check for all 621 attack steps of the AAD. This resulted in a discovery of more detailed attack patterns (CAPEC sub patterns). Furthermore, we identified additional automotive-related attack techniques in the AAD that are currently not covered by CAPEC. In sum, we were able to define 25 of these AAD patterns (abbreviated with the identifier *AAD*) and assigned them together with the other identified CAPEC sub patterns to our mapping. In Section 5, the results are presented in detail.

Last, in step ⑤, we extract mitigations from each UN threat and its mapped CAPEC patterns and list them in our results. This can be seen as an extension of the already provided UN mitigation list with automotive-relevant CAPEC mitigations. In case no mitigations for specific CAPEC meta patterns are proposed, its sub patterns and linked MITRE ATT&CK patterns are examined.

Overall, we want to emphasize that our mapping should not be considered rigid and finished. Both CAPEC (currently version 3.7) and CWE (currently version 4.8) are constantly updated. Likewise, new threats can also be defined in UN R155. An occurrence of new attacks, vulnerabilities, and mitigations can therefore result in new contexts. However, this work is intended to define a basis applicable in security development, test processes, or security assessments to describe and analyze attacks, vulnerabilities, and mitigations. The mapping can also serve as a basis for an extension or concretization of individual elements, such as attack techniques of the work of Pekaric et al. [51].

5 RESULTS

In this section, we explain the results of our mapping. For each UN threat, a table is created, which includes corresponding CAPEC *Meta Attack Patterns*, sub patterns, and associated CWEs. Assigned STRIDE categories and technical domains are presented as shown in Figure 2. If there is a related attack step in our attack database, the number of occurrences and a reference to an exemplary attack step is given. We also give a reference to a corresponding database attack identifier (e.g.,

Table 2. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T1

UN-T1: Back-end servers used as a means to attack a vehicle or extract data				
D. + S.	Attack Pattern	CWE-ID	R. + A.	
S S E	CAPEC-21: Exploitation of Trusted Identifiers	290, 346, 602, 642, 664	[19]	1
S S	CAPEC-593: Session Hijacking	287	—	—
S S I	CAPEC-94: Adversary in the Middle (AiTM)	287, 290	[55]	5
S H I	CAPEC-116: Excavation	200, 1243	[19]	1
S S R	CAPEC-151: Identity Spoofing	287, 327	—	—
S H S	CAPEC-154: Resource Location Spoofing	290, 693, 706	—	—
S S	CAPEC-159: Redirect Access to Libraries	706	[17]	1
S H S	CAPEC-616: Establish Rogue Location	290, 693	—	—
S H T	CAPEC-161: Infrastructure Manipulation	117, 306, 345, 346, 349, 1221	—	—
S I	CAPEC-169: Footprinting	200	—	—
S I	AAD-1: Location/Trajectory Tracking through Server	200	[35]	5
S H T	CAPEC-176: Configuration/Environment Manipulation	15, 1233, 1234, 1304, 1328	—	—
S H S	CAPEC-212: Functionality Misuse	345, 346, 522, 640, 757, 1242	[34]	2
S I	CAPEC-224: Fingerprinting	200	—	—
S I	CAPEC-312: Active OS Fingerprinting	200	—	—
S I	CAPEC-313: Passive OS Fingerprinting	200	—	—
S I	CAPEC-541: Application Fingerprinting	200, 497	—	—
S T	CAPEC-272: Protocol Manipulation	707, 757	—	—
S T	CAPEC-220: Client Server Protocol Manipulation	757	—	—
S T	CAPEC-278: Web Services Protocol Manipulation	707	—	—
S H S	CAPEC-560: Use of Known Domain Credentials	262, 263, 307, 308, 309, 522, 654, 1273	—	—
R E				
Mitigations:				
UN R155: M1, M2, M8; CAPEC-ID: 21, 94, 116, 151, 154, 159, 169, 176→203, 212, 224, 278, 560;				
ATT&CK Techniques: T1082, T1557, T1574.008				

Additionally, references (R.) for related real-world attacks and the amount of occurrences (A.) in our database [60] is given. Bold printed patterns denote meta patterns, and normal printed patterns below denote related sub patterns. Regarding mitigations, a → is a meta-to-sub pattern relationship and indicates mitigations in the sub pattern.

ID2018_Ruef_SSA1#) in the text. Furthermore, extracted mitigations are represented by the UN threat, CAPEC pattern, or MITRE ATT&CK element in which they are listed. Since mitigation descriptions can be very detailed, only the IDs are mentioned due to space constraints.

5.1 Back-End Server-Related Threats UN-T1 through UN-T3

First, we look at UN-T1 through UN-T3, which affect back-end servers that communicate with vehicles. Since these threats only relate to back-end servers instead of communication channels, the domains *Software* S and *Hardware* H are assigned. In Table 2, UN-T1 and related attack patterns are illustrated. UN-T1 describes attacks in which a vehicle is attacked via a back-end server. This opens up a variety of attack possibilities. Thus, we assign all STRIDE categories S T R I E with exception of *Denial of Service* D (covered by UN-T2). A total of 12 CAPEC meta patterns, 9 sub patterns, and 33 CWEs are assigned to UN-T1. In total, we validated 6 mappings by real-world attacks from our database [60]: for CAPEC-212, various vehicle functions, such as climate

Table 3. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T2

UN-T2: Services from back-end server being disrupted, affecting the operation of a vehicle				
D. + S.	Attack Pattern	CWE-ID	R. + A.	
  	CAPEC-74: Manipulating State	693, 1245, 1253	–	–
  	CAPEC-212: Functionality Misuse	640, 645, 1242, 1246, 1281	[53]	1
Mitigations:				
UN R155: M3; CAPEC-ID: 74, 212				

control, were activated via a webserver (AAD ID: ID2018_Leyden_MSA1_Step2_1# [34]). With regard to CAPEC-159, attackers (ID2019_Dash_MSA1_Step2_1 [17]) inserted a link to a malicious library. For CAPEC-116, user credentials were read from a web server via a third-party app (ID2014_Dhanjani_MSA2_Step1 [19]). For CAPEC-94, data traffic was intercepted between a vehicle and a related app (ID2018_Ruef_SSA1# [55]). Thus, the attackers found the vehicle location and control car systems. With regard to CAPEC-21, attackers (ID2014_Dhanjani_MSA1_Step1 [19]) created a weak user account via a mobile app, which allowed vehicle access. Special attention should be paid to AAD-1: *Location/Trajectory Tracking through Server*, which we have defined and assigned as a sub pattern for CAPEC-169: *Footprinting*. This pattern is inspired by attack examples of UN R155 [69] and Pekaric et al. [51], whose work also identified location tracking and trajectory tracking attacks on vehicles from scientific publications. Since we identified this attack type in 5 attack steps in our database [60] (e.g., ID2018_Leyden_MSA1_Step1 [34]), we defined AAD-1 as an own pattern. In terms of mitigations, a total of 3 high-level mitigation strategies are proposed by UN R155. Due to the mapping, 12 CAPEC patterns provide additional guidance and further reference 3 ATT&CK mitigations. In addition, 1 CAPEC pattern or 1 ATT&CK technique can consist of multiple mitigations.

UN-T2 aims to disrupt a back-end server or its services in such a way that vehicles communicating with the server are affected. For this reason, only the STRIDE category *Denial of Service* applies to this threat. As shown in Table 3, we assign 2 CAPEC patterns with respective mitigations and 8 CWEs for UN-T2. Regarding CAPEC-212, attackers (ID2019_Rekawek_SSA2# [53]) disrupted requests for vehicle health reports from a server.

UN-T3 describes attacks which aim for lost or compromised back-end server data. Such attacks delete, manipulate, or extract data on a server. Thus, we only assign attack patterns concerning the STRIDE categories *Tampering* and *Information Disclosure*. As shown in Table 4, this results in an assignment of 7 meta patterns, 2 sub patterns, and 14 CWEs, of which 9 CAPEC patterns including the sub patterns of CAPEC-165 (namely CAPEC-73, CAPEC-635, and CAPEC-636) propose reasonable mitigations. CAPEC-63: *Cross-Site Scripting (XSS)* and CAPEC-66: *SQL Injection* are mainly known from attacks on web applications. In the automotive context, this concerns web applications that are accessed, for example, via a vehicle's internal browser. In the AAD, we found attacks for both patterns. For ID2019_Curry_SSA1# [15], attackers performed a cross-site scripting attack by modifying a naming string in the vehicle management web application. For ID2018_Stykas_SSA1# [63], an SQL injection was performed on a car alarm web application, allowing a root account to be created.

5.2 Communication-Related Threats UN-T4 through UN-T11

UN-T4 through UN-T11 concern attacks on internal and external communication channels of a vehicle. For this reason, only the domain *Communications*  is assigned to these threats. For UN-T4, this results in the mapping shown in Table 5.

Table 4. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T3

UN-T3: Vehicle-related data held on back-end servers being lost or compromised (“data breach”)			
D. + S.	Attack Pattern	CWE-ID	R. + A.
S H I	CAPEC-116: Excavation	200, 1243	– –
S T	CAPEC-165: File Manipulation	20, 96, 116, 184, 697	– –
S T	CAPEC-242: Code Injection	94	– –
S T	CAPEC-63: Cross Site Scripting (XSS)	20, 79	[15] 2
S T	CAPEC-248: Command Injection	77	– –
S T	CAPEC-66: SQL Injection	89, 1286	[63] 2
S H I	CAPEC-548: Contaminate Resource	200	– –
S T	CAPEC-586: Object Injection	502	– –
S T	CAPEC-594: Traffic Injection	940	– –
Mitigations:			
UN R155: M1, M2, M4, M5, M8; CAPEC-ID: 116, 165→73, 165→635, 165→636, 242, 242→63, 248, 248→66, 586			

Table 5. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T4

UN-T4: Spoofing of messages or data received by the vehicle			
D. + S.	Attack Pattern	CWE-ID	R. + A.
C S	CAPEC-148: Content Spoofing	345	[40] 50
C S	CAPEC-151: Identity Spoofing	290, 327, 346	– –
C S	AAD-2: Sybil Attack	290, 327, 346	– –
C S	CAPEC-154: Resource Location Spoofing	290, 300	– –
C S	CAPEC-616: Establish Rogue Location	290, 300	– –
C S	AAD-3: Position Forging Attack	290, 300	[45] 7
Mitigations:			
UN R155: M10, M11; CAPEC-ID: 151, 154			

UN-T4 describes data or message spoofing to a vehicle. For this reason, only CAPEC patterns corresponding to the STRIDE category *Spoofing* are assigned. This results in an assignment of 3 meta patterns, 3 sub patterns, and 5 CWEs. We assign AAD-2: *Sybil Attack* to CAPEC-151, as did Pekaric et al. [51], because this attack technique aims to capture multiple identities to affect a network. While there is no such attack in our attack database, this technique has been identified as a realistic threat in several publications on Vehicular Ad Hoc Networks (VANETs) and is cited in UN R155 [69] as an exemplary attack for UN-T4. We assign AAD-3: *Position Forging Attack* to CAPEC-154 since it involves manipulations of vehicle position data. This almost exclusively affects the Global Positioning System (GPS) or navigation systems. For this attack technique, we found 7 related attack steps in the AAD (e.g., ID2019_Murray_SSA1# [45]). Furthermore, for CAPEC-148, we found 50 attack steps in our database, such as spoofing CAN messages to intervene with the vehicle steering (ID2013_Miller_MSA11_Step3_2# [40]). As countermeasures, mainly security controls for message authentication and integrity are required (UN-M10, UN-M11, and CAPEC-151) while the mapping adds monitoring (CAPEC-154) to the list.

UN-T5 describes manipulations of vehicle data via communication systems. This threat corresponds to the STRIDE category *Tampering*. As seen in Table 6, we assign 4 meta patterns, 2 sub patterns, and 3 CWEs and extract 4 patterns with relevant mitigations. A special case is CAPEC-28: *Fuzzing* since this meta pattern is only assigned to the domain *Software* by CAPEC. However,

Table 6. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T5

UN-T5: Communication channels used to conduct unauthorized manipulation, deletion, or other amendments to vehicle-held code/data				
D. + S.	Attack Pattern	CWE-ID	R. + A.	
 	CAPEC-28: Fuzzing	707	–	–
 	AAD-4: Communication Channel Fuzzing	707	[29]	3
 	CAPEC-216: Communication Channel Manipulation	306	–	–
 	CAPEC-272: Protocol Manipulation	707	–	–
 	CAPEC-277: Data Interchange Protocol Manipulation	707	–	–
 	CAPEC-624: Hardware Fault Injection	1319	–	–
Mitigations:				
UN R155: M6, M7, M10; CAPEC-ID: 28, 216, 272→278, 624				

Table 7. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T6

UN-T6: Communication channels permit untrusted/unreliable messages to be accepted or are vulnerable to session hijacking/replay attacks				
D. + S.	Attack Pattern	CWE-ID	R. + A.	
 	CAPEC-94: Adversary in the Middle (AiTM)	290, 294, 300	[4]	4
 	CAPEC-148: Content Spoofing	290, 294	–	–
 	AAD-5: Replay Attack	290, 294	[40]	22
Mitigations:				
UN R155: M10; CAPEC-ID: 94; ATT&CK Techniques: T1557				

in the automotive domain, fuzzing attacks have also been performed on communication systems, and various tools, such as CAN bus fuzzers, exist for this purpose. Therefore, we assign CAPEC-28 to the domain *Communications* and introduce *AAD-4: Communication Channel Fuzzing*. For this pattern, 3 attacks exist in the AAD (e.g., ID2017_KeenLab_MSA3_Step2_1 [29]). Here, attackers were fuzzing Bluetooth messages, which resulted in a reboot of a vehicle head unit.

UN-T6 characterizes attacks in which valid messages are sent to vehicle systems but have negative effects on the vehicle. This is achieved in particular by spoofing messages. We assign 2 CAPEC meta patterns, 1 sub pattern, and 3 CWEs, as shown in Table 7. We further introduce *AAD-5: Replay Attack* and assign it to CAPEC-148. Replay attacks are explicitly mentioned for UN-T6 in UN R155 [69]. A variety of replay attacks exist in our attack database (22 attacks). In ID2013_Miller_MSA10_Step2_1# [40], attackers replayed valid CAN messages to compromise vehicle functions, such as displaying wrong speed values in the instrument cluster. Furthermore, for CAPEC-94, we identified 4 real-world attacks, such as ID2019_Kaspersky_MSA1_Step1 [4], in which attackers performed an Man-in-the-Middle attack on a Bluetooth communication channel. Especially *CAPEC-94 Man in the Middle* proposes multiple mitigation strategies and even refers to ATT&CK technique T1557, which lists a total of 7 mitigations and further detection mechanisms.

UN-T7 deals with threats to obtain information through communication channels. This results in 3 associated meta patterns, 3 sub patterns, and 4 CWEs (Table 8), of which 4 patterns contain mitigations. *CAPEC-651: Eavesdropping* and *CAPEC-157: Sniffing Attacks* describe classic attack techniques on communication channels to sniff information. For both patterns, related attacks exist in the AAD. For CAPEC-651, attackers violated the privacy of a person (ID2006_Aijaz_SSA10# [1]). For CAPEC-157, we found 52 related attack steps. An example is ID2015_Miller_MSA2_Step1 [42], where attackers sniffed and analyzed a vehicle's D-Bus communication. For CAPEC-192, we found

Table 8. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T7

UN-T7: Information can be readily disclosed, such as through eavesdropping on communications or through allowing unauthorized access to sensitive files or folders				
D. + S.	Attack Pattern	CWE-ID	R. + A.	
C I	CAPEC-117: Interception	319	—	—
C I	CAPEC-157: Sniffing Attacks	311	[42]	52
C I	CAPEC-651: Eavesdropping	200	[1]	1
C I	CAPEC-169: Footprinting	200	—	—
C I	AAD-6: Location/Trajectory Tracking through Communication Link	200	[1]	2
C I	CAPEC-192: Protocol Analysis	326	[71]	18
Mitigations:				
UN R155: M8, M12; CAPEC-ID: 117, 117→157, 117→651, 169				

Table 9. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T8

UN-T8: Denial of service attacks via communication channels to disrupt vehicle functions				
D. + S.	Attack Pattern	CWE-ID	R. + A.	
C D	CAPEC-125: Flooding	770	[40]	3
C D	CAPEC-130: Excessive Allocation	770	[29]	3
C D	CAPEC-594: Traffic Injection	940	[41]	19
C D	CAPEC-607: Obstruction	693	—	—
C D	CAPEC-601: Jamming	693	[71]	16
C D	CAPEC-624: Hardware Fault Injection	693, 1319	[22]	2
C D	AAD-7: Bus Off Attack	693, 1319	[24]	2
Mitigations:				
UN R155: M13; CAPEC-ID: 125, 125→487, 125→489, 130, 624; ATT&CK Techniques: T1499.003				

18 attacks (e.g., ID2019_Urquhart_MSA3_Step1 [71]). Here, attackers analyzed the VW-TP 2.0 communication protocol to disable the start/stop system. For *CAPEC-169: Footprinting*, we defined *AAD-6: Location/Trajectory Tracking through Communication Link*. This sub pattern describes attacks in which the position of a vehicle is determined by signals or messages emitted by communication systems. Two related attacks exist in the AAD, such as ID2006_Aijaz_SSA8# [1] in which a vehicle was tracked based on messages from a known network node.

UN-T8 characterizes *Denial of Service* attacks on communication channels. This involves blocking or exhausting a channel, but also, for example, continuously sending requests to an Electronic Control Unit (ECU) within a short time window to disrupt its function. For this threat, we identified 5 meta patterns, 2 sub patterns, 4 CWEs, and 7 referenced mitigations, as shown in Table 9. *CAPEC-601: Jamming* is commonly used to disrupt wireless communication channels or physical signals and can be performed on all vehicular wireless communications or signal transmissions. CAPEC-607 and its sub patterns do not detail mitigations since they are strongly technology dependent and would need to be supported on the transmission and receiving devices. Still, we identified 16 related attacks in our database (e.g., jamming key fob signals, ID2019_Urquhart_MSA1_Step1 [71]). For CAPEC-130, TSP signals were suppressed to launch a rouge base station (ID2017_KeenLab_MSA5_Step3_2 [29]). For CAPEC-125, a CAN communication channel was flooded with high-priority messages (ID2013_Miller_SSA1# [40]). For CAPEC-594, attackers injected messages into the internal network to shut down an ECU (ID2014_Miller_SSA2# [41]). CAPEC-624 is used for

Table 10. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T9

UN-T9: An unprivileged user is able to gain privileged access to vehicle systems					
D. + S.	Attack Pattern	CWE-ID	R. + A.		
C S	CAPEC-151: Identity Spoofing	290, 327, 346	–	–	
C S	AAD-8: Accessing Communication Channel	290, 327, 346	[12]	2	
C S	AAD-9: Relay Attack	290, 327, 346	[57]	65	
C S	AAD-10: Key Fob Spoofing	290, 327, 346	[21]	11	
Mitigations:					
UN R155: M9; CAPEC-ID: 151					

Table 11. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T10

UN-T10: Viruses embedded in communication media are able to infect vehicle systems					
D. + S.	Attack Pattern	CWE-ID	R. + A.		
C T	CAPEC-240: Resource Injection	CWE-99	[25]	1	
Mitigations:					
UN R155: M14; CAPEC-ID: 240					

attacks in which hardware faults are caused by attacks. In ID2002_Gupta_SSA1# [22], attackers performed a denial of service, which targeted a WLAN network's MAC layer. *AAD-7: Bus-Off Attack* is a refinement of that attack in which error messages are provoked on a communication channel until the transmitting unit is blocked for further communication (e.g., CAN bus in ID2008_Iehira_MSA1_Step1 [24]).

Table 10 shows our mapping for UN-T9. This threat describes attacks in which unauthorized access to vehicle systems is achieved via a communication channel. Since this threat is based on a communication system and these do not have privilege levels in the sense of STRIDE category *Elevation of Privileges*, we consider this threat as a *Spoofing* attack. We assign *CAPEC-151: Identity Spoofing* as a meta pattern and distinguish 3 sub patterns. *AAD-8: Accessing Communication Channel* describes gaining access to a communication system. This can be done either by physical contact or by IT access. In ID2018_Computertest_MSA1_Step4_3 [12], attackers gained access to CAN bus by accessing the communication chip on an ECU. *AAD-9: Relay Attack* is an attack on keyless entry systems in vehicles. Here, valid key fob signals are triggered and relayed by 2 attackers that are close to the vehicle and key fob. Relay attacks often end with vehicle theft. This attack technique is most frequently found in our attack database (65 attacks, e.g., ID2015_Rüsberg_SSA1# [57]). *AAD-10: Key Fob Spoofing* is similar to *AAD-9* in that valid signals from key fobs are also sent to a vehicle to open or start it. With *Key Fob Spoofing*, however, the radio signal is intercepted, recorded, or copied beforehand and reused later. This is often done in conjunction with a jamming attack so valid key fob signals do not reach the vehicle. In ID2018_Greenberg_MSA1_Step3_2# [21] and 10 other AAD entries, this technique was used.

UN-T10 describes an infection of a vehicle system with a virus that is introduced via a communication medium (e.g., **Universal Serial Bus (USB)** stick). This corresponds to the STRIDE category *Tampering*. As shown in Table 11, we only assign 1 meta pattern and CWE for this threat. In ID2018_Innovator_MSA1_Step2_1 [25], this pattern was used to inject a virus with a malicious USB stick.

UN-T11, shown in Table 12, is similar to UN-T10 and describes an introduction of malicious content via in-vehicle and external messages. As with UN-T10, we also assign *Tampering*, CAPEC-240, and CWE-99 for this threat. In addition, we assign CAPEC-594 and CWE-940. For both patterns, we found related attacks in the AAD. For CAPEC-594, malicious messages

Table 12. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T11

UN-T11: Messages received by the vehicle (e.g., X2V or diagnostic messages), or transmitted within it, contain malicious content				
D. + S.	Attack Pattern	CWE-ID	R. + A.	
C T	CAPEC-240: Resource Injection	99	[30]	1
C T	CAPEC-594: Traffic Injection	940	[41]	4
Mitigations:				
UN R155: M10, M15; CAPEC-ID: 240				

were injected via a WLAN connection (ID2014_Miller_SSA6# [41]). For CAPEC-240, attackers (ID2019_Keen_MSA1_Step2_1# [30]) injected malicious code into steering control messages.

5.3 Software Update Related Threats UN-T12 through UN-T13

UN-T12 and UN-T13 refer to attacks affecting the vehicle update procedures. This concerns the domains *Software*, *Hardware*, and *Communications*. UN-T12 refers to manipulation or compromise of update procedures. This involves both physical updates (e.g., via a diagnostic tester) and **Over-The-Air (OTA)** updates via the back-end server. Since such attacks mainly violate the integrity of a system or procedure, we assign *Tampering*. In addition, it is possible to abuse existing functions to extend privileges (e.g., via diagnostic security access). Therefore, we also assign the STRIDE category *Elevation of Privileges*. We assign a total of 4 meta patterns, 4 sub patterns, 12 CWEs, and a total of 9 mitigation references as shown in Table 13. CAPEC-186 describes a software update on a component with modified software. Such attacks are also found in our attack database (e.g., ID2015_Miller_MSA4_Step4_3# [42]). This step is usually preceded by CAPEC-669, which describes the process of manipulating software as in ID2010_Koscher_MSA1_Step3_2 [33]. In terms of mitigations, CAPEC-440 refers to ATT&CK T1200 and its sub patterns CAPEC-535 and CAPEC-677. UN-T13 describes the prevention of an update, so it is a *Denial of Service*. We assign 3 meta patterns, 1 sub pattern, and 10 CWEs to this threat, as shown in Table 14. As with UN-T8, CAPEC-601: *Jamming* is used, for example, to prevent an OTA update. For CAPEC-212, attackers (ID2019_Ng_SSA1# [47]) turned off a vehicle engine by misusing update request mechanisms.

5.4 Human-Related Threat UN-T15

UN-T15 is a special threat, as it does not directly target automotive-related technologies but people who have an influence on these technologies (e.g., the vehicle user). As seen in Table 15, we only assign 2 meta patterns and 3 CWEs at this point. The first meta pattern, CAPEC-410, concerns obtaining information, for example, via social engineering. In ID2018_Costantino_SSA1# [14], a malicious vehicle app was distributed by social engineering. Thus, private data was gathered (e.g., by activating the infotainment microphone to record conversations). For this reason, the STRIDE category *Information Disclosure* is assigned. The second pattern, CAPEC-416, concerns the manipulation of a human to create conditions for an attack. For instance, a human could be manipulated into attaching a specific compromised device to a vehicle that would allow an attacker to influence its behavior.

5.5 Connectivity-Related Threats UN-T16 through UN-T18

UN-T16 through UN-T18 characterize attacks on connectivity features of a vehicle—that is, entities responsible for external communication, such as telematic functions. This concerns the domains *Software*, *Hardware*, and *Communications*. UN-T16 describes attacks to manipulate

Table 13. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T12

UN-T12: Misuse or compromise of update procedures				
D. + S.	Attack Pattern	CWE-ID	R. + A.	
S T	CAPEC-184: Software Integrity Attack	494	–	–
S T	CAPEC-186: Malicious Software Update	494	[42]	8
S T	CAPEC-669: Alteration of a Software Update	494	[33]	6
S H	CAPEC-212: Functionality Misuse	241, 345, 706, 346, 640,	–	–
T E		757, 522, 1242, 1281		
S C T	CAPEC-272: Protocol Manipulation	707, 757	–	–
C T	CAPEC-277: Data Interchange Protocol Manipulation	707	–	–
H T	CAPEC-440: Hardware Integrity Attack	1263	–	–
H T	CAPEC-534: Malicious Hardware Update	1263	–	–
Mitigations:				
UN R155: M11, M16; CAPEC-ID: 184→186, 184→669, 212, 272→278, 440→535, 440→677; ATT&CK Techniques: T1200				

Table 14. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T13

UN-T13: It is possible to deny legitimate updates				
D. + S.	Attack Pattern	CWE-ID	R. + A.	
S C D	CAPEC-130: Excessive Allocation	404, 770, 1325	–	–
S H D	CAPEC-212: Functionality Misuse	640, 645, 1242, 1246, 1281	[47]	1
S H C D	CAPEC-607: Obstruction	664, 693	–	–
C D	CAPEC-601: Jamming	693	–	–
Mitigations:				
UN R155: M3; CAPEC-ID: 130, 212; ATT&CK Techniques: T1499.003				

Table 15. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T15

UN-T15: Legitimate actors are able to take actions that would unwittingly facilitate a cyber attack				
D. + S.	Attack Pattern	CWE-ID	R. + A.	
S I	CAPEC-410: Information Elicitation	311, 319	[14]	2
S H T I D	CAPEC-416: Manipulate Human Behavior	311, 319, 693	–	–
Mitigations:				
UN R155: M18, M19; CAPEC-ID: 416				

connectivity functions, which is mainly reflected by the STRIDE categories *Tampering* and *Denial of Service*. As shown in Table 16, 5 meta patterns, 5 sub patterns, and 20 CWEs are assigned, whereas a total of 6 entries also contain relevant mitigations. In combination with CAPEC-624, this threat in particular relates to attacks on vehicle sensors. We define AAD-12, AAD-13, and AAD-14 according to attacks in our AAD. In *AAD-12: Sensor Disruption Attack*, the function of a sensor is disrupted, resulting in the sensor not being able to perform its function reliably (e.g., LiDAR sensor in ID2015_Petit_MSA1_Step1 [52]). In *AAD-13: Sensor Blinding Attack*, sensors are blinded. For example, a camera might be blinded by light irradiation so that objects, such as street signs, cannot be detected as in ID2015_Petit_SSA1# [52]. *AAD-14: Sensor Signal Manipulation* describes a manipulation of the signal captured by a sensor. For example, Petit et al. [52] sent false echo signals to a LiDAR sensor, causing the sensor to detect nonexistent objects

Table 16. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T16

UN-T16: Manipulation of the connectivity of vehicle functions enables a cyber attack, which can include telematics, systems that permit remote operations, and systems using short-range wireless communications				
D. + S.	Attack Pattern	CWE-ID	R. + A.	
	CAPEC-130: Excessive Allocation	404, 770, 1325	–	–
	CAPEC-161: Infrastructure Manipulation	306, 346, 707, 1221	–	–
	AAD-15: Environment Attack	117, 306, 345, 346, 349	[30]	2
	CAPEC-212: Functionality Misuse	1242, 1281	–	–
	AAD-11: Enabling/Disabling Functions via Connectivity Feature	241, 345, 346, 640, 706, 757	[64]	5
	CAPEC-216: Communication Channel Manipulation	306	–	–
	CAPEC-624: Hardware Fault Injection	1256, 1319, 1332, 1334	–	–
	AAD-12: Sensor Disruption Attack	1247, 1319	[52]	1
	AAD-13: Sensor Blinding Attack	1319	[52]	2
	AAD-14: Sensor Signal Manipulation	1319	[52]	2
Mitigations:				
UN R155: M20; CAPEC-ID: 130, 212, 216, 624; ATT&CK Techniques: T1499.003				

Table 17. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T17

UN-T17: Hosted third-party software, such as, entertainment applications, used as a means to attack vehicle systems				
D. + S.	Attack Pattern	CWE-ID	R. + A.	
	CAPEC-74: Manipulating State	693	–	–
	CAPEC-148: Content Spoofing	345	–	–
	CAPEC-169: Footprinting	200	–	–
	AAD-16: Location/Trajectory Tracking through Device/Application	200	[64]	5
	CAPEC-173: Action Spoofing	923, 1021	–	–
	CAPEC-416: Manipulate Human Behavior	693	–	–
Mitigations:				
UN R155: M21; CAPEC-ID: 74, 169, 173, 416				

(ID2015_Petit_MSA1_Step2_1#). Another sub pattern is characterized by AAD-11. This pattern describes an exploitation of existing connectivity features to enable or disable vehicle functions. An example is the control of the auxiliary heating via a smartphone or disabling a theft alert from an app (ID2019_Stykas_MSA2_Step3_2# [64]). AAD-15: *Environment Attack* is particularly relevant for autonomous vehicles. In this case, the integrity of the vehicle environment is compromised to influence the vehicle. As an example, adversarial pictures are displayed to trigger windshield wipers (ID2019_Keen_SSA1# [30]).

UN-T17 describes threats that influence a vehicle via third-party software. We therefore only assign the domain *Software*. As illustrated in Table 17, 5 meta patterns, 1 sub pattern, and 5 CWEs are assigned, of which 4 meta patterns provide mitigations. Additionally, AAD-16 describes tracking of vehicles with a special device or application. This can be a device installed by an attacker or driver. Attacks have been observed in reality in which third party anti-theft tracking devices were attacked (ID2019_Stykas_MSA1_Step2_1 [64]). Such devices usually communicate with a

Table 18. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T18

UN-T18: Devices connected to external interfaces (e.g., USB ports, OBD port) used as a means to attack vehicle systems				
D. + S.	Attack Pattern	CWE-ID	R. + A.	
	CAPEC-148: Content Spoofing	693	[71]	1
	CAPEC-212: Functionality Misuse	1242	–	–
	CAPEC-441: Malicious Logic Insertion	1263	–	–
	CAPEC-456: Infected Memory	1263	[29]	3
	CAPEC-452: Infected Hardware	1263	–	–
Mitigations:				
UN R155: M22; CAPEC-ID: 212, 441→456, 441→638; ATT&CK Techniques: T1542.002				

smartphone app that a driver uses to locate the vehicle. Compromising such devices or applications can lead to vehicle tracking/locating by an attacker.

UN-T18 describes threats in which a device attached to vehicle interfaces is used for an attack (Table 18). Thus, the domain *Hardware* is assigned. CAPEC-456 and CAPEC-452 are particularly relevant here. CAPEC-456: *Infected Memory* describes attacks through a compromised or infected storage medium, such as a USB stick. Researchers from Keen Security Lab (ID2017_KeenLab_MSA2_Step2_1 [29]) did that to obtain root privileges on a vehicles head unit. CAPEC-452: *Infected Hardware* describes a compromised hardware device, such as an infected ECU, via which an attack takes place. Whereas CAPEC-456 proposes anti-virus software for detection, CAPEC-452 refers to the sub pattern CAPEC-638: *Altered Component Firmware*, which suggests to use hardware known to not be vulnerable to these attack types and references ATT&CK technique T1542.002, which demands regular firmware updates. For CAPEC-148, we found an attack by Urquhart et al. [71] (ID2019_Urquhart_SSA1#) in which vehicle functions, such as a high beam assist, were activated, enabled, or configured.

5.6 Software- and Data-Related Threats UN-T19 through UN-T25

UN-T19 through UN-T25 are used to describe attacks that target data or software code in a vehicle. Since this particularly affects components on which this data and code is stored, UN-T19 through UN-T25 are assigned the domains *Software* and *Hardware*. UN-T19 (shown in Table 19) describes attacks in which data or software code is extracted from a vehicle. This threat is assigned with the STRIDE category *Information Disclosure*. In total, we assign 7 meta patterns, 11 sub patterns, and 25 CWEs. We can extract 3 mitigations from UN R155, 10 CAPEC patterns, and 4 ATT&CK techniques with several measures each. Classic fingerprinting attacks are represented via CAPEC-312, CAPEC-313, and CAPEC-541. CAPEC-188, CAPEC-167, CAPEC-37, and CAPEC-190 represent techniques of *Reverse Engineering*. This particularly concerns *White Box Reverse Engineering* of ECU software. For CAPEC-37, we identified 21 database entries (e.g., ID2015_Miller_MSA1_Step2_1 [42]). Here, the firmware of an ECU was disassembled to acquire information about a Wi-Fi key calculation algorithm. For CAPEC-190, we found 25 related attack steps in the AAD. For example, Koscher et al. [33] reverse engineered the firmware of a telematics ECU (ID2010_Koscher_MSA1_Step2_1). Extracting data or code from a component (e.g., reading the firmware of an ECU) is described via CAPEC-54 and CAPEC-545. For CAPEC-54, we found 14 attacks, such as ID2011_Checkoway_MSA5_Step1 [8], in which an ECU's firmware was extracted. For CAPEC-545, we found 8 attacks, such as ID2011_Checkoway_MSA1_Step3_2 [8], in which attackers dumped the memory content from an infotainment ECU. Intercepting information is described by CAPEC-117. In ID2018_WMC_SSA1# [73], attackers intercepted firmware information over a debug interface of an ECU. Furthermore, CAPEC-651: *Eavesdropping* and CAPEC-157:

Table 19. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T19

UN-T19: Extraction of vehicle data/code				
D. + S.	Attack Pattern	CWE-ID	R. + A.	
 	CAPEC-94: Adversary in the Middle (AiTM)	287	–	–
  	CAPEC-116: Excavation	200, 1243	–	–
  	CAPEC-54: Query System for Information	209	[8]	14
  	CAPEC-545: Pull Data from System Resources	1243, 1258, 1266, 1272 1278, 1323, 1324	[8]	8
  	CAPEC-117: Interception	319	[73]	1
 	CAPEC-157: Sniffing Attacks	311	[40]	2
  	CAPEC-651: Eavesdropping	200	–	–
 	CAPEC-169: Footprinting	200	–	–
 	CAPEC-300: Port Scanning	200	[42]	10
  	CAPEC-188: Reverse Engineering	203, 1300, 311, 312, 524, 798, 912, 1323, 1324	–	–
  	CAPEC-167: White Box Reverse Engineering	311, 312, 524, 798, 912 1323, 1324	–	–
  	CAPEC-37: Retrieve Embedded Sensitive Data	226, 311, 312, 1258 1266, 1272, 1278, 1301	[42]	21
 	CAPEC-190: Reverse Engineer an Executable to Expose Assumed Hidden Functionality	912	[33]	25
  	CAPEC-212: Functionality Misuse	522, 706, 757, 1242	[33]	3
 	CAPEC-224: Fingerprinting	200, 497	–	–
 	CAPEC-312: Active OS Fingerprinting	200	–	–
 	CAPEC-313: Passive OS Fingerprinting	200	–	–
 	CAPEC-541: Application Fingerprinting	200, 497	–	–
Mitigations:				
UN R155: M7, M8, M11; CAPEC-ID: 94, 116, 116→54, 117, 117→157, 117→651, 169, 188, 212, 224; ATT&CK Techniques: T1005, T1046, T1552.004, T1557				

Sniffing Attacks are assigned (the latter, e.g., in ID2013_Miller_MSA7_Step2_1 [40]). *Port Scanning* attacks (CAPEC-300) exist in the automotive field not only via classic TCP/IP and UDP/IP protocols as known from IT (ID2015_Miller_SSA2# [42]) but also via automotive-specific protocols as presented by Ring et al. [54]. Finally, we found 3 related attacks for CAPEC-212. In ID2010_Koscher_MSA1_Step1 [33], attackers read sensitive memory areas of an ECU via OBD.

UN-T20 deals with manipulations of data and software code, resulting in an integrity violation. For this reason, we assign the STRIDE category *Tampering*. For CAPEC-74 (Table 20), we also assign *Repudiation* since manipulation of a particular system state can lead to obfuscation of an attack and is therefore deniable. In total, we assign 7 CAPEC meta patterns, 3 sub patterns, and 16 CWEs and extract 10 patterns with mitigations for UN-T20. CAPEC-100 describes classic buffer overflow attacks, which have been observed in the automotive sector (e.g., in ID2011_Checkoway_MSA3_Step4_3# [8]). *AAD-17: Adversarial Attack* describes attacks that target artificial intelligence algorithms (e.g., deep learning algorithms) by changing an algorithm's input data in such a way that data is misclassified. In the automotive context, various attacks were demonstrated targeting traffic sign recognition. Input images of traffic signs were changed minimally and imperceptibly to the human eye, leading to misclassification of the sign (e.g., wrong speed limit). For this type of attack, 28 real-world attacks exist in our AAD (e.g., ID2016_Papernot_SSA1# [50]). *AAD-18: Changing Operation Mode* describes attacks that

Table 20. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T20

UN-T20: Manipulation of vehicle data/code					
D. + S.	Attack Pattern	CWE-ID	R. + A.		
 	CAPEC-28: Fuzzing	20, 74	[10]	2	
  	CAPEC-74: Manipulating State	353, 372, 693, 1265	[64]	3	
 	AAD-18: Changing Operation Mode	353, 372, 693, 1265	[1]	5	
 	CAPEC-123: Buffer Manipulation	119, 120, 131, 805	–	–	
 	CAPEC-100: Overflow Buffers	119, 120, 131, 805	[8]	6	
 	CAPEC-129: Pointer Manipulation	682, 822, 823	[48]	2	
 	CAPEC-153: Input Data Manipulation	20, 1039	–	–	
 	AAD-17: Adversarial Attack	20, 1039	[50]	28	
 	CAPEC-176: Configuration/Environment Manipulation	15	–	–	
 	CAPEC-248: Command Injection	77	[8]	3	
Mitigations:					
UN R155: M7; CAPEC-ID: 28, 74, 123, 123→100, 153→92, 153→126, 153→267, 176→203, 248, 248→66					

Table 21. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T21

UN-T21: Erasure of data/code					
D. + S.	Attack Pattern	CWE-ID	R. + A.		
  	CAPEC-74: Manipulating State	353, 372, 693, 1265	[43]	1	
Mitigations:					
UN R155: M7; CAPEC-ID: 74					

put vehicle components, such as ECUs, into a specific state (e.g., a specific service mode as in ID2006_Aijaz_SSA4# [1]). Switching to such a mode often results in the component's function being restricted. For CAPEC-74, attackers changed the e-mail address and reset the password of a vehicle tracking app (ID2019_Stykas_MSA1_Step1 [64]). For CAPEC-28, attackers applied fuzzing attacks to a vehicle diagnostic tool (ID2015_Smith_SSA1# [10]). Regarding CAPEC-248, attackers injected malicious commands to a telematics ECU (ID2011_Checkoway_MSA4_Step3_2# [8]). Furthermore, in ID2018_KeenLab_MSA1_Step2_1 [48], arbitrary data was written to specific memory addresses.

UN-T21 explicitly describes deleting vehicle data or code. Since this threat is comparatively specific, only 1 meta pattern and 4 CWEs are assigned, as shown in Table 21. As with UN-T20, the STRIDE categories *Tampering* and *Repudiation* are relevant. An exemplary attack was performed in ID2016_Miller_MSA1_Step3_2 [43] in which attackers deleted the firmware from an ECU.

UN-T22 describes the introduction of malware into a component. We assign the domain *Software* to this threat. As shown in Table 22, this allows 4 CAPEC meta patterns, 4 sub patterns, and 3 CWEs to be assigned, of which 6 patterns provide mitigations. CAPEC-175, CAPEC-242, and CAPEC-549 have similar attack descriptions. At the sub pattern level, they differ in more detail. CAPEC-251 and CAPEC-253 describe local or remote inclusion of code—that is, code is injected into a target component that either replaces previous code or is added to this code. Examples for such attacks exist in the AAD (ID2006_Aijaz_SSA5# [1] for CAPEC-251 and ID2018_Computertest_MSA1_Step6_5# [12] for CAPEC-253). *CAPEC-542: Targeted Malware* targets specific technologies and vulnerabilities that are exploited by code execution. For example, in ID2019_Cimpanu_SSA1# [11], the firmware code of an infotainment ECU was executed by exploiting a bug. *CAPEC-442: Infected Software* aims to inject malicious code into a system

Table 22. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T22

UN-T22: Introduction of malware				
D. + S.	Attack Pattern	CWE-ID	R. + A.	
S T	CAPEC-175: Code Inclusion	829	–	–
S T	CAPEC-251: Local Code Inclusion	829	[1]	1
S T	CAPEC-253: Remote Code Inclusion	829	[12]	2
S T	CAPEC-242: Code Injection	94	[31]	3
S T	CAPEC-441: Malicious Logic Insertion	284	–	–
S T	CAPEC-442: Infected Software	284	[6]	1
S T	CAPEC-549: Local Execution of Code	829	–	–
S T	CAPEC-542: Targeted Malware	829	[11]	1
Mitigations:				
UN R155: M7; CAPEC-ID: 175→251, 175→253, 242, 242→63, 441→442, 549				

Table 23. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T23

UN-T23: Introduction of new software or overwrite existing software				
D. + S.	Attack Pattern	CWE-ID	R. + A.	
S T	CAPEC-184: Software Integrity Attack	494	–	–
S T	CAPEC-186: Malicious Software Update	494	[31]	4
S T	CAPEC-240: Resource Injection	99	–	–
S T E	CAPEC-441: Malicious Logic Insertion	284	–	–
S T E	CAPEC-442: Infected Software	284	[42]	3
Mitigations:				
UN R155: M7; CAPEC-ID: 184→186, 184→669, 240, 441→442				

(ID2014_Brewster_MSA1_Step1 [6]). Furthermore, for CAPEC-242, attackers injected shell code into a vehicle's Wi-Fi chip (ID2019_KeenLab_MSA1_Step3_2 [31]).

UN-T23 describes an introduction of new software or replacement of existing software into a system. As illustrated in Table 23, we assign 3 meta patterns, 2 sub patterns, and 3 CWEs corresponding to the STRIDE category *Tampering*. As for UN-T22, CAPEC-441 and CAPEC-442 are also assigned. These patterns are used in UN-T22 to describe the introduction of malicious software; however, they are used in UN-T23 to describe, for example, modifications of ECU firmware (as in ID2015_Miller_MSA3_Step3_2 [42]). CAPEC-186 describes the software update of a component with malicious software (e.g., ID2019_KeenLab_MSA1_Step2_1 [31]). Since this can also lead to an attainment of higher privileges, the STRIDE category *Elevation of Privilege* is additionally assigned for CAPEC-184 and CAPEC-186.

UN-T24 exclusively characterizes *Denial of Service* attacks. As shown in Table 24, 9 CAPEC meta patterns and 18 CWEs are assigned to this threat, affecting both software and hardware. The mapping allows us to extract 9 patterns with mitigations, and 2 additional references to ATT&CK exists. Further, we found related attacks for 4 mappings in our database. For CAPEC-130, attackers performed a denial of service attack on a robotic vehicle (ID2019_Dash_MSA1_Step5_2# [17]). For CAPEC-25, a navigation ECU was set into a boot loop (ID2018_Ruef_SSA2# [55]). Regarding CAPEC-594, the web browser on an ECU was crashed (ID2015_Mahaffey_MSA1_Step2_1 [38]). In ID2016_Miller_MSA1_Step1 [43] (CAPEC-74), a vehicle's park assistance ECU was deactivated by setting it into bootrom mode.

UN-T25 targets the manipulation of parameters and is categorized as *Tampering*. As shown in Table 25, 5 meta patterns and 20 CWEs are assigned while underlying sub patterns lead to a

Table 24. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T24

UN-T24: Disruption of systems or operations					
D. + S.	Attack Pattern	CWE-ID	R. + A.		
S D	CAPEC-25: Forced Deadlock	412, 567, 662, 667, 833, 1322	[55]	1	
S H D	CAPEC-74: Manipulating State	693, 1245, 1253	[43]	3	
S D	CAPEC-125: Flooding	404, 770	–	–	
S D	CAPEC-130: Excessive Allocation	404, 770, 1325	[17]	2	
S D	CAPEC-131: Resource Leak Exposure	404	–	–	
S D	CAPEC-227: Sustained Client Engagement	770, 772	–	–	
S D	CAPEC-594: Traffic Injection	940	[38]	1	
S H D	CAPEC-607: Obstruction	693, 664	–	–	
H D	CAPEC-624: Hardware Fault Injection	1248, 1319, 1334	–	–	
Mitigations:					
UN R155: M13; CAPEC-ID: 25, 74, 125, 125→487, 125→489, 130, 131, 227, 624; ATT&CK Techniques: T1499, T1499.003					

Table 25. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T25

UN-T25: Manipulation of vehicle parameters					
D. + S.	Attack Pattern	CWE-ID	R. + A.		
S H T	CAPEC-26: Leveraging Race Conditions	362, 363, 366, 368, 662, 665, 691, 1223, 1254, 1298	–	–	
S T	CAPEC-28: Fuzzing	20, 74	[1]	1	
S H T	CAPEC-74: Manipulating State	353, 372, 693, 1245, 1253, 1265, 1271	–	–	
S T	CAPEC-137: Parameter Injection	88	[71]	2	
S T	CAPEC-153: Input Data Manipulation	20	–	–	
Mitigations:					
UN R155: M7; CAPEC-ID: 26, 28, 74, 137, 153→92, 153→126, 153→267					

total of 7 CAPEC-IDs with mitigation strategies. For CAPEC-28, attackers modified an ECU by fuzzing (ID2006_Aijaz_SSA6# [1]). Regarding CAPEC-137, chip tuning was performed to modify parameters on the engine ECU (ID2019_Urquhart_MSA5_Step2_1 [71]).

5.7 Protection-Related Threats UN-T26 through UN-T32

The last threat category is based on vulnerabilities resulting from missing or insufficient protection mechanisms. This affects all domains and STRIDE categories, as for UN-T26 in Table 26. UN-T26 deals with attacks that aim to circumvent cryptographic mechanisms or exploit an inadequate implementation. Since there is a large number of cryptographic mechanisms designed to protect different objectives, there is a wide range of possible attack techniques. This is reflected in Table 26. For this threat, 13 CAPEC meta patterns, 5 sub patterns, and 43 CWEs are assigned, of which 11 patterns and 1 ATT&CK technique reference mitigations. Many patterns group themselves into specific STRIDE categories. CAPEC-192 deals with the analysis of protocols (e.g., PKES protocols and related key fob functions in ID2019_Wouters_MSA1_Step4_3 [75]) and are assigned to the category *Information Disclosure*. Its sub pattern *CAPEC-97: Cryptanalysis* consists of an analysis of cryptographic algorithms to obtain information on potential weak points. We found 11 related attacks in our database, such as ID2013_Verdult_MSA1_Step3_2 [72] in which a crypto cipher was analyzed to recover a secret key. Regarding brute force related patterns (CAPEC-112 and its sub patterns), we found real-world attacks for each pattern. CAPEC-20 and CAPEC-49 describe

Table 26. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T26

UN-T26: Cryptographic technologies can be compromised or are insufficiently applied			
D. + S.	Attack Pattern	CWE-ID	R. + A.
	CAPEC-21: Exploitation of Trusted Identifiers	290, 346, 602, 642, 664	– –
	CAPEC-22: Exploiting Trust in Client	287, 290, 693	– –
	CAPEC-112: Brute Force	326, 330, 521	[53] 2
	CAPEC-20: Encryption Brute Forcing	326, 327, 693, 1204	[72] 3
	CAPEC-49: Password Brute Forcing	257, 521	[42] 13
	AAD-25: Brute Force on Diagnostic Security Access	257, 521	[33] 2
	CAPEC-114: Authentication Abuse	287, 1244	[46] 2
	CAPEC-115: Authentication Bypass	287	– –
	CAPEC-122: Privilege Abuse	269, 732, 1317	[29] 3
	CAPEC-192: Protocol Analysis	326	[75] 3
	CAPEC-97: Cryptanalysis	327, 1204, 1240, 1241, 1279	[72] 11
	CAPEC-212: Functionality Misuse	640, 645, 1242, 1246, 1281	– –
	CAPEC-233: Privilege Escalation	269, 285, 325, 328, 638, 1311	[43] 4
	CAPEC-272: Protocol Manipulation	707, 757	– –
	CAPEC-390: Bypassing Physical Security	1263	[20] 2
	CAPEC-554: Functionality Bypass	359, 424	[48] 1
	AAD-19: Integrity Protection Bypass	693	[20] 3
	CAPEC-560: Use of Known Domain Credentials	262, 263, 307, 308, 309, 522, 654, 1273	[38] 4
Mitigations:			
UN R155: M23; CAPEC-ID: 21, 22, 112, 112→20, 112→49, 122, 122→17, 122→180, 192→97, 212, 560; ATT&CK Techniques: T1548			

brute force attacks on passwords (e.g., WLAN password in ID2015_Miller_MSA1_Step3_2 [42]) or encryption (e.g., encryption key of crypto cipher in ID2013_Verdult_MSA1_Step4_3# [72]). AAD-25: *Brute Force on Diagnostic Security Access* specifically targets the automotive sector since it describes attacks on the security access specified in the diagnostic standard Unified Diagnostic Services (ISO 14229 [26]). An exemplary attack on this mechanism was performed by Koscher et al. [33] in ID2010_Koscher_SSA1#. For the category *Spoofing*, CAPEC-114: *Authentication Abuse* (applied in ID2019_Google_MSA1_Step2_1# [46]) and CAPEC-115: *Authentication Bypass* are assigned, which specifically violate authentication mechanisms. CAPEC-21, CAPEC-22, and CAPEC-560 (applied in ID2015_Mahaffey_MSA1_Step4_3 [38]) are also assigned to this category. CAPEC-122: *Privilege Abuse* (ID2017_KeenLab_MSA1_Step3_2# [29]) and CAPEC-233: *Privilege Escalation* (ID2016_Miller_MSA2_Step2_1 [43]) are assigned to the category *Elevation of Privilege*. With respect to bypassing integrity protection, *Tampering* patterns, such as CAPEC-390: *Bypassing Physical Security* (e.g., in ID2007_Sparks_SSA2# [20]) and AAD-19: *Integrity Protection Bypass*, are assigned. The latter is used, for example, in software-based attacks to bypass Trusted Platform Modules (ID2007_Sparks_SSA1# [20]).

UN-T27 describes the manipulation or compromise of parts or supplies. This affects the *Tampering* of both *Software* and *Hardware*. As shown in Table 27, we assign 2 meta patterns and 14 CWEs. In terms of mitigations, 6 sub patterns and 1 ATT&CK technique list countermeasures. For CAPEC-113, we found a corresponding real-world attack, where attackers accessed

Table 27. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T27

UN-T27: Parts or supplies could be compromised to permit vehicles to be attacked					
D. + S.	Attack Pattern	CWE-ID	R. + A.		
S H T	CAPEC-113: Interface Manipulation	346, 489, 693, 695, 912, 1209, 1242, 1259, 1267, 1270, 1294, 1302, 1313	[44]	1	
H T	CAPEC-439: Manipulation During Distribution	1269	–	–	
Mitigations:					
UN R155: M23; CAPEC-ID: 113→36, 113→121, 113→133, 439→522, 439→523, 439→524; ATT&CK Techniques: T1195					

Table 28. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T28

UN-T28: Software or hardware development permits vulnerabilities					
D. + S.	Attack Pattern	CWE-ID	R. + A.		
S H T E	CAPEC-74: Manipulating State	353, 372, 693, 1245, 1253, 1265, 1271	–	–	
S H T	CAPEC-124: Shared Resource Manipulation	1189, 1331	–	–	
S H E	CAPEC-233: Privilege Escalation	269, 1264	–	–	
S E	AAD-20: Exploiting Software Bug/Vulnerability	269	[29]	1	
H E	AAD-21: Exploiting Hardware Bug/Vulnerability	1264	[16]	2	
S H T	CAPEC-438: Modification During Manufacture	732	[8]	2	
H T E	CAPEC-624: Hardware Fault Injection	1247, 1256, 1319, 1332, 1334	–	–	
Mitigations:					
UN R155: M23; CAPEC-ID: 74, 624; ATT&CK Techniques: T1195, T1548					

a vehicle via a custom smartphone app and a custom On-Board Diagnostics (OBD) interface (ID2019_Rndash_SSA1# [44]).

UN-T28 refers to threats that arise during development of software and hardware systems. We assign 5 meta patterns, 2 sub patterns, and 17 CWEs to this threat, and get a total of 5 references to mitigations. As shown in Table 28, this concerns modifications during development (CAPEC-438), or the manipulation of resources (CAPEC-124) and states (CAPEC-74). For CAPEC-438, attackers developed a malicious smartphone app that was used to create a Bluetooth connection (ID2011_Checkoway_MSA3_Step3_2 [8]). Thus, authorized communication with the telematics unit was possible. AAD-20 and AAD-21 describe the exploitation of a bug or vulnerability that has arisen during development in software or hardware. For both patterns, real-world attacks exist. For example, for AAD-20, a vulnerability of the Temporary Mobile Subscriber Identity was exploited (ID2017_CISA_SSA2# [16]). For AAD-21, a memory corruption vulnerability was exploited in a vehicle browser (ID2017_KeenLab_MSA4_Step2_1 [29]).

UN-T29 describes vulnerabilities contained in a network design. Thus, we assign the domain *Communications*. This results in a mapping of 4 meta patterns, 3 sub patterns, 8 CWEs, and a total of 8 references to mitigations, as shown in Table 29. AAD-22 and AAD-23 are particularly noteworthy. AAD-22: *Distributed Denial of Service* is used as a sub pattern of CAPEC-125 and describes a denial of service attack that is executed by multiple network nodes simultaneously (ID2002_Gupta_SSA4# [22]). AAD-23: *Black Hole Attack* describes attacks in which messages sent on a network are discarded by a specific node (black hole) without the sender being aware of this. We have not yet been able to find this type of attack in our AAD. However, UN R155 [69] and Pekaric et al. [51] specify this attack technique for the automotive sector. For

Table 29. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T29

UN-T29: Network design introduces vulnerabilities					
D. + S.	Attack Pattern	CWE-ID	R. + A.		
  	CAPEC-94: Adversary in the Middle (AiTM)	290, 294, 300	[8]	26	
 	CAPEC-125: Flooding	770	—	—	
 	AAD-22: Distributed Denial of Service	770	[22]	3	
  	CAPEC-161: Infrastructure Manipulation	306, 346, 707	—	—	
 	AAD-23: Black Hole Attack	306	—	—	
 	CAPEC-169: Footprinting	200	—	—	
 	CAPEC-300: Port Scanning	200	—	—	
Mitigations:					
UN R155: M23; CAPEC-ID: 94, 125, 125→487, 125→489, 169; ATT&CK Techniques: T1046, T1557					

Table 30. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T30

UN-T30: Physical loss of data					
D. + S.	Attack Pattern	CWE-ID	R. + A.		
 	CAPEC-440: Hardware Integrity Attack	1263	—	—	
 	CAPEC-401: Physically Hacking Hardware	1263			
 	CAPEC-507: Physical Theft	693	[18]	1	
Mitigations:					
UN R155: M24; CAPEC-ID: 507 ATT&CK Techniques: T1200					

CAPEC-94, we identified 22 related attacks in our database. For example, Checkoway et al. [8] (ID2011_Checkoway_MSA2_Step3_2#) spoofed CAN commands via a remotely controlled OBD device.

UN-T30 describes the physical loss of data. This threat is a special case, as it is not explicitly listed in the UN R155 [69] list of threats. However, it is referenced in the associated list of mitigations. For this reason, we include it in our work. As can be seen in Table 30, 2 meta patterns, 1 sub pattern, and 2 CWEs are assigned, of which CAPEC-507 and ATT&CK T1200 list countermeasures. For CAPEC-507, attackers stole identities from the dark web to steal vehicles in ID2018_FleetNews_SSA1# [18].

UN-T31 describes the unintentional transmission of data. For an attacker, this threat represents an information gain, which is why the STRIDE category *Information Disclosure* is assigned. This allowed us to assign 2 meta patterns, 2 sub patterns, and 10 CWEs, of which 2 patterns further provide mitigations (Table 31). CAPEC-192: *Protocol Analysis* describes an information gain by analyzing deployed protocols in software, hardware, and communication systems. CAPEC-188 and CAPEC-189 describe reverse engineering techniques, especially the black box variant. These also include side-channel attacks (CAPEC-622), in which physical properties, such as power consumption of a component (e.g., ECU), are measured in certain operating situations to obtain information (ID2006_Lemke_SSA3# [59]).

UN-T32 describes physical manipulations of a component, which is why the domain *Hardware* and STRIDE category *Tampering* are applied. As seen in Table 32, we assign 3 meta patterns, 2 sub patterns, and 10 CWEs and identify 3 mitigation entries in total. AAD-24: *Physical Environment Attack* should be highlighted. This pattern is based on AAD-15 and describes attacks on a vehicle's environment. However, only physical manipulations are considered. For example, an attacker could physically manipulate or obscure a traffic sign to influence traffic sign recognition of an autonomous vehicle. In ID2019_Keen_SSA2# [30], attackers placed stickers on the road to mislead

Table 31. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T31

UN-T31: Unintended transfer of data can occur				
D. + S.	Attack Pattern	CWE-ID	R. + A.	
	CAPEC-188: Reverse Engineering	203, 1300, 1323, 1324	–	–
	CAPEC-189: Black Box Reverse Engineering	203, 1300	–	–
	CAPEC-622: Electromagnetic Side Channel Attack	203, 1300	[59]	8
	CAPEC-192: Protocol Analysis	326, 327, 1204 1240, 1241, 1279	–	–
Mitigations:				
UN R155: M24; CAPEC-ID: 188, 188→622				

Table 32. Mapping of CAPEC Patterns, CWEs, STRIDE (S.), and Technology Domains (D.) to UN-T32

UN-T32: Physical manipulation of systems can enable an attack				
D. + S.	Attack Pattern	CWE-ID	R. + A.	
	CAPEC-113: Interface Manipulation	693, 1209, 1242, 1259, 1267, 1270, 1294, 1302, 1313	[1]	1
	CAPEC-161: Infrastructure Manipulation	693	–	–
	AAD-24: Physical Environment Attack	693	[30]	6
	CAPEC-440: Hardware Integrity Attack	1263	–	–
	CAPEC-401: Physically Hacking Hardware	1263	[4]	12
Mitigations:				
UN R155: M9; CAPEC-ID: 113→121; ATT&CK Techniques: T1200				

the lane detection algorithm. For CAPEC-113, we found an attack in the AAD in which attackers manipulated the physical connection between ECUs (ID2006_Aijaz_SSA2# [1]). For CAPEC-401, we identified 12 real-world attacks, for example, ID2019_Kaspersky_MSA1_Step2_1# [4], where a malicious device was connected to a remotely controlled OBD device, which was installed in the vehicle.

5.8 Summary

To refine threats of the UN R155 and to create a common understanding of attacks, weaknesses/vulnerabilities, and mitigations, this section presents a mapping between the 31 UN threats and 59 CAPEC *Meta Attack Patterns*. Threats and attack patterns were classified according to the 3 technical domains of *Software*, *Hardware*, and *Communications* as well as the 6 STRIDE categories. In addition to the meta patterns, 33 CAPEC *Standard Attack Patterns* and 3 *Detailed Attack Patterns* were assigned. From the 546 currently existing CAPEC attack patterns (version 3.7), 95 patterns were considered. A total of 150 out of 927 existing CWEs (version 4.8) were considered (7 *Pillar*, 32 *Class*, and 111 *Base* CWEs). In terms of mitigations, UN R155 lists 23 mitigation strategies, whereas our approach allowed us to find 83 mapped CAPEC patterns with proposed mitigations, and each pattern can consist of 1 or more countermeasures and partially references additional mitigations from the ATT&CK taxonomy. Overall, this resulted in a total of 204 mappings, which are shown in the preceding tables. In addition, 1 mapping corresponds to 1 table row. Of these 204 mappings, 95 were validated by real-world security attacks identified in our AAD. Thereby, a total of 25 new automotive-relevant attack patterns (AAD) were defined and taken into account in the mapping. The 95 validated mappings were included in the AAD by integrating the CWEs into the AAD *Vulnerability* category. The CAPEC, UN threats, and 25 automotive-relevant attack patterns were integrated into the AAD *Attack Class* category. In this way, all 361 real-world attacks on vehicles

and their 621 attack steps located in the AAD are assigned to 1 of the 95 validated mappings. As a result, the mapping data can be extracted from the AAD [60] and reused in vehicle development and testing.

6 DISCUSSION

In the course of our mapping, ambiguities and limitations have come up that we want to discuss in this section. In addition, we provide further reasoning on the validation through our AAD and elaborate on the key advantages from our approach.

6.1 Ambiguity of UN Threats

When analyzing the UN threats and their descriptions, it is noticeable that they are ambiguous and partly overlap. Thus, there are several UN threats that can apply to the same attack. UN-T12, for example, includes attacks on OTA updates transmitted by a vehicle manufacturer's back-end server. UN-T1 also deals with attacks that affect a vehicle via a back-end server. Thus, the question arises as to which of these two threats is used to describe a back-end server attack. As a solution to this challenge, our goal was to refine the UN threats by mapping STRIDE, CAPEC patterns, and CWEs to an extent that the most applicable attack pattern can be chosen. In the preceding example, UN-T12 and a corresponding CAPEC pattern (e.g., CAPEC-186) would be most suitable if an attack via a back-end server targets a software update. For other back-end-related attacks, UN-T1 would be used.

6.2 Ambiguity of Mappings between UN Threats and CAPEC Patterns

The UN threats are formulated in generic terms (e.g., UN-T27 and UN-T28). Therefore, it is possible to assign the same CAPEC patterns to several different UN threats. For example, *CAPEC-441: Malicious Logic Insertion* is assigned to both UN-T22 and UN-T18. To refine the mapping, the STRIDE categories and technological domains are used at this point. UN-T22 has been assigned the domain *Software*, whereas only *Hardware* applies to UN-T18. CAPEC-441 has three sub patterns: *CAPEC-442: Infected Software*, *CAPEC-452: Infected Hardware*, and *CAPEC-456: Infected Memory*. Since CAPEC-442 only affects *Software*, only an assignment to UN-T22 is reasonable. Analogous, CAPEC-452 and CAPEC-456 are assigned to UN-T18 since they affect *Hardware*. Thus, for this example, the meta pattern is the same for both threats, but associated sub patterns differ and therefore provide further details on the attack context which results in a more explicit/less ambiguous mapping. This is also reflected in the associated CWEs (CWE-284 for UN-T22, CWE-1263 for UN-T18). Thus, a combination of UN threat, technological domain, STRIDE category, and CAPEC/AAD pattern refines attacks and sets them into a specific context to make the attack pattern selection as precise as possible.

6.3 Ambiguity of Mapped Mitigations

Compared to the UN threats, UN mitigations are formulated even more generally. The reason for this is the objective to formulate widely applicable, technology-independent regulations. This allows an assignment of the same UN mitigations to several UN threats. For instance, *UN-T1: Back-end servers used as a means to attack a vehicle or extract data* and *UN-T19: Extraction of vehicle data/code* both propose mitigation *M8: Through system design and access control it should not be possible for unauthorized personnel to access personal or system critical data*. This example shows that selecting countermeasures is context based and must always be considered in relation to threats or associated attack patterns. Accordingly, mitigations listed by CAPEC patterns should also take into account associated UN threat scenarios. A concrete application of CAPEC mitigations in the automotive domain cannot be shown in this context, but mitigations from CAPEC should give an

idea of accepted countermeasures from adjacent domains since such a listing does not yet exist in the automotive domain.

6.4 Missing Links between CAPEC and CWE

Our approach provides a continuous mapping of UN threats, CAPEC patterns, and CWEs. This means that for each UN threat, there is at least one mapped CAPEC meta pattern and one CWE. However, not every CAPEC pattern has a link to a CWE. For example, *CAPEC-607: Obstruction* has no CWE assignment. In such a case, we considered the CWE mapping of associated sub patterns. For CAPEC-607, however, even the hierarchically lower sub patterns do not have a CWE link. Only at the lowest hierarchical level can associated CWEs be found. In case they did not match an assigned STRIDE category or technology domain, we assigned a CWE ourselves (for UN-T8 and CAPEC-607, e.g., CWE-693, see Table 9). Another example is CWE-1039, which targets adversarial input perturbations in recognition mechanisms. Thus, we assigned it to CAPEC-153 and especially *AAD-17: Adversarial Attack* (e.g., attacks on traffic sign recognition in autonomous vehicles).

6.5 Validation through the Automotive Attack Database

We used our AAD [60] to validate the mappings since it offers a broad spectrum of attacks and vulnerabilities. This database, as of June 2023, contains 361 real-world attacks and 621 attack steps on vehicles. Included attacks originate from different sources, such as scientific publications, trade journals, press articles, or vulnerability databases. We were able to validate 95 of 204 mappings using the AAD. However, even though not every mapping could be validated by our database, we still consider those mappings as valuable. Examples are *AAD-2: Sybil Attack* (see Table 5) and *AAD-23: Black Hole Attack* (see Table 29). For both patterns, we could not find a real-world attack in our database. However, both techniques are cited by UN R155 as exemplary attacks for associated UN threats. In addition, Pekaric et al. [51] identified several publications that consider these attacks realistic for the automotive domain. By expanding our database over time, currently not validated mappings might be validated in the future. We do not see a static description format in our approach but rather a basic taxonomy that can be adapted over time. Since CAPEC and CWE are also subject to version control and will potentially be extended or adapted in future versions, regular alignment of our mapping is recommended. However, a possible limitation could be that our mapping approach could not cover all new attacks, which might be added to the AAD in the future.

6.6 Benefits and Advantages

Our approach is to combine knowledge about security attacks, vulnerabilities, and mitigations from different domains with the automotive domain. This creates a uniform description of security-specific terminology. Furthermore, it can support processes within the vehicle development or life cycle. One example is TARA, in which potential security threats to a vehicle are identified and assessed for their risk. The threats of UN R155 are of particular importance here. Through our mapping to CAPEC patterns, STRIDE, and technological domains, different attack techniques for a given threat can be analyzed at this point. Knowledge of underlying weaknesses is provided through linked CWEs. This allows a more accurate assessment of risks and probabilities of specific attacks. In particular, since CWEs are used in the NVD (one of the largest vulnerability databases) and in our AAD, there is a direct link to existing concrete vulnerabilities based on real-world security attacks. Thus, this knowledge can be integrated into the TARA process. For example, Zelle et al. [78] present the ThreatSurf approach, which creates attack paths automatically during TARA. They further manually map these paths to threats of the UN R155. By using our mappings, this process could be automated. Based on the results of TARA, mitigations are usually derived to protect a

vehicle from identified threats. Again, our approach can support this, as both CAPEC patterns and UN threats propose mitigations. Similar to TARA, our approach can be applied in security testing. Since security testing attempts to uncover remaining vulnerabilities in a system through performing attacks (e.g., in penetration testing), testers can benefit from our approach by using existing knowledge about attacks and vulnerabilities from linked taxonomies. As the underlying data of taxonomies and databases is publicly available, there is also potential to automate development and testing activities using appropriate tools. In prior work [62], we gave an overview of how our mapping is used in a model-based security testing approach for automatic attack path generation by extracting the attack and vulnerability information from the AAD [60]. Beyond the vehicle development process, there are opportunities in the area of type approval. Type approval involves checking whether regulations have been complied with during development, before a vehicle or its components are allowed to be produced. In terms of security for vehicle types, this means checking whether an exhaustive TARA was performed that considers relevant threats, whether proportionate mitigations were selected, and how a system has been tested. Thus, our mapping gives auditors insight into the state of the art in common attack patterns that trigger threats referenced by UN R155, which allows them to match existing attacks, vulnerabilities, and mitigations with results and processes of the development of a vehicle under test. Beyond the automotive domain, our mapping approach can be applied to other domains. In the work of Ansari and Nazir [3], for example, CAPEC is used for the risk assessment of smart homes. Here, instead of UN threats, specific threats for smart homes could be used to achieve a mapping between taxonomies. The MITRE ATT&CK [67] linked to CAPEC serves the domains *Enterprise* and *Mobile*, as well as Industrial Control Systems. Another application domain could be safety-critical systems, such as medical or chemical plants.

7 CONCLUSION

With the increasing amount of electrical and IT components, modern vehicles are regarded as complex systems that combine a variety of different technologies and technical domains. Thus, there is a wide range of security attacks that can differ significantly across a vehicle's subsystems. In this article, we linked taxonomies from different domains to the automotive domain to create a common understanding of attack techniques, related weaknesses/vulnerabilities, and possible mitigations. In particular, we mapped automotive threats of UN R155 to attack patterns of CAPEC and linked them to the STRIDE categories and three technical domains (*Software*, *Hardware*, and *Communications*). Additionally, already existing links to CWEs and mitigations strategies of UN R155 and CAPEC were considered. The mappings were validated using our AAD [60], which currently contains 361 attacks (consisting of 621 attack steps). In total, 95 of 204 mappings could be validated in this way. Thereby, 25 additional automotive attack patterns were defined according to attacks from the AAD. The presented results serve to support security activities in the context of vehicle development and beyond through linked knowledge regarding attacks, vulnerabilities, and mitigations. However, the main limitation of this work is that there are still 109 mappings that could not be validated so far. The reason for this is that attacks related to these mappings have yet to occur in reality. As we have to expect new attacks on vehicle systems, we also expect new UN R155, CAPEC, and CWE entries. Thus, future work can involve the search for further attacks for our AAD to update/extend our mapping. To achieve this, the mappings were incorporated into the AAD [60]. Where applicable, the database entries of the AAD's *Attack Class* and *Vulnerability* categories were extended by UN threats, CAPEC patterns, and CWEs of our mappings. This data can be extracted from the database by SQL queries. In addition, future case studies could investigate how our approach can be integrated into individual phases of the development and type approval

process. This allows for the creation of a tool that can gather data from diverse taxonomies and link it to our mapping, presenting another conceivable option.

REFERENCES

- [1] Amer Aijaz, Bernd Bochow, Florian Dötzer, Andreas Festag, Matthias Gerlach, Rainer Kroh, and Tim Leinmüller. 2006. Attacks on inter vehicle communication systems—An analysis. In *Proceedings of the 3rd International Workshop on Intelligent Transportation (WIT'06)*. 189–194.
- [2] Emad Aliwa, Omer Rana, Charith Perera, and Peter Burnap. 2021. Cyberattacks and countermeasures for in-vehicle networks. *ACM Computing Surveys* 54, 1 (2021), 1–37.
- [3] Adeeb Mansoor Ansari and Mohammed Nazir. 2022. Risk assessment of security vulnerabilities in smart home using CAPEC and defensive goals. In *Advances in Data and Information Sciences*. Springer, 705–722.
- [4] AO Kaspersky Lab. 2019. On the IoT Road: Perks, Benefits and Security of Moving Smartly. Retrieved February 14, 2024 from <https://securelist.com/on-the-iot-road/91833/>
- [5] Harold Booth, Doug Rike, and Gregory Witte. 2013. The National Vulnerability Database (NVD): Overview. Retrieved February 14, 2024 from <https://www.nist.gov/publications/national-vulnerability-database-nvd-overview>
- [6] Thomas Brewster. 2014. Zubie: This Car Safety Tool ‘Could Have Given Hackers Control Of Your Vehicle.’ Retrieved February 14, 2024 from <https://www.forbes.com/sites/thomasbrewster/2014/11/07/car-safety-tool-could-have-given-hackers-control-of-your-vehicle/#4986296f1481>
- [7] Ondrej Burkacky, Johannes Deichmann, Benjamin Klein, Klaus Pototzky, and Gundbert Scherf. 2020. Cybersecurity in Automotive: Mastering the Challenge. Retrieved February 14, 2024 from <https://www.mckinsey.com/industries/automotive-and-assembly/our-insights/cybersecurity-in-automotive-mastering-the-challenge>
- [8] Stephen Checkoway, Damon McCoy, Brian Kantor, Danny Anderson, Hovav Shacham, Stefan Savage, Karl Koscher, Alexei Czeskis, Franziska Roesner, and Tadayoshi Kohno. 2011. Comprehensive experimental analyses of automotive attack surfaces. In *Proceedings of the 20th USENIX Security Symposium*.
- [9] Abdullahi Chowdhury, Gour Karmakar, Joarder Kamruzzaman, Alireza Jolfaei, and Rajkumar Das. 2020. Attacks on self-driving cars and their countermeasures: A survey. *IEEE Access* 8 (2020), 207308–207342.
- [10] Catalin Cimpanu. 2015. Cars Exposed to Hacking Inside Car Dealerships. Retrieved February 14, 2024 from <https://news.softpedia.com/news/cars-exposed-to-hacking-inside-car-dealerships-493572.shtml>
- [11] Catalin Cimpanu. 2019. Tesla car hacked at Pwn2Own contest. *ZDNet*. Retrieved February 14, 2024 from <https://www.zdnet.com/article/tesla-car-hacked-at-pwn2own-contest/>
- [12] Computest. 2018. The Connected Car—Ways to Get Unauthorized Access and Potential Implications. Retrieved February 14, 2024 from https://www.computest.nl/documents/9/The_Connected_Car_Research_Rapport_Computest_april_2018.pdf
- [13] Gianpiero Costantino, Marco de Vincenzi, and Ilaria Matteucci. 2022. In-depth exploration of ISO/SAE 21434 and its correlations with existing standards. *IEEE Communications Standards Magazine* 6, 1 (2022), 84–92. <https://doi.org/10.1109/MCOMSTD.0001.2100080>
- [14] Gianpiero Costantino, Antonio La Marra, Fabio Martinelli, and Ilaria Matteucci. 2018. CANDY: A social engineering attack to leak information from infotainment system. In *Proceedings of the 2018 IEEE 87th Vehicular Technology Conference (VTC Spring'18)*. 1–5.
- [15] Sam Curry. 2019. Cracking My Windshield and Earning 10,000 on the Tesla Bug Bounty Program. Retrieved February 14, 2024 from <https://samcurry.net/cracking-my-windshield-and-earning-10000-on-the-tesla-bug-bounty-program/>
- [16] Cybersecurity and Infrastructure Security Agency. 2017. ICS Advisory (ICSA-17-208-01): Continental AG Infineon S-Gold 2 (PMB 8876). Retrieved February 14, 2024 from <https://www.cisa.gov/uscert/ics/advisories/ICSA-17-208-01>
- [17] Pritam Dash, Mehdi Karimibiuki, and Karthik Pattabiraman. 2019. Out of control: Stealthy attacks against robotic vehicles protected by control-based techniques. In *Proceedings of the 35th Annual Computer Security Applications Conference*. 660–672.
- [18] Matt de Prez. 2018. Dark Web Identity Theft Used to Steal Accident Replacement Hire Cars. Retrieved February 14, 2024 from https://www.fleetnews.co.uk/news/car-industry-news/2018/09/06/dark-web-identity-theft-used-to-steal-accident-replacement-hire-cars?utm_source=Adestra&utm_term=&utm_content=Dark+web+identity+theft+used
- [19] Nitesh Dhanjani. 2014. Cursory Evaluation of the Tesla Model S: We Can't Protect Our Cars Like We Protect Our Workstations. Retrieved February 14, 2024 from <https://www.dhanjani.com/blog/2014/03/curosry-evaluation-of-the-tesla-model-s-we-cant-protect-our-cars-like-we-protect-our-workstations.html>
- [20] Evan R. Sparks and Sean W. Smith. 2007. A Security Assessment of Trusted Platform Modules. Retrieved February 14, 2024 from https://digitalcommons.dartmouth.edu/cgi/viewcontent.cgi?article=1052&context=senior_theses

- [21] Andy Greenberg. 2018. Hackers can steal a Tesla model S in seconds by cloning its key fob. *WIRED*. Retrieved February 14, 2024 from <https://www.wired.com/story/hackers-steal-tesla-model-s-seconds-key-fob/>
- [22] Vikram Gupta, Srikanth Krishnamurthy, and Michalis Faloutsos. 2002. Denial of service attacks at the MAC layer in wireless ad hoc networks. In *Proceedings of MILCOM 2002*. IEEE, 1118–1123. <https://doi.org/10.1109/MILCOM.2002.1179634>
- [23] Anne Honkaranta, Tiina Leppänen, and Andrei Costin. 2021. Towards practical cybersecurity mapping of stride and CWE—A multi-perspective approach. In *Proceedings of the 2021 29th Conference of the Open Innovations Association (FRUCT'21)*. 150–159.
- [24] Kazuki Iehira, Hiroyuki Inoue, and Kenji Ishida. 2018. Spoofing attack using bus-off attacks against a specific ECU of the CAN bus. In *Proceedings of the 2018 15th IEEE Annual Consumer Communications and Networking Conference (CCNC'18)*. 1–4.
- [25] IoT Innovator. 2018. Zingbox identifies cybersecurity threat for cars and drivers; reveals SMS-commanded malware infection to car 'infotainment' system. *IoT Innovator*. Retrieved February 14, 2024 from <https://www.iotinnovator.com/zingbox-identifies-cybersecurity-threat-for-cars-and-drivers-reveals-sms-commanded-malware-infection-to-car-infotainment-system/>
- [26] ISO. 2006. *ISO 14229:2006: Road Vehicles—Unified Diagnostic Services (UDS)—Specification and Requirements*. ISO.
- [27] ISO. 2018. *ISO 26262-1:2018: Road Vehicles—Functional Safety: Part 1: Vocabulary*. ISO.
- [28] ISO. 2021. *ISO/SAE 21434:2021: Road Vehicles—Cybersecurity Engineering*. ISO
- [29] Keen Security Lab. 2017. Experimental Security Assessment of BMW Cars: A Summary Report. Retrieved February 14, 2024 from https://keenlab.tencent.com/en/whitepapers/Experimental_Security_Assessment_of_BMW_Cars_by_KeenLab.pdf
- [30] Keen Security Lab. 2019. Experimental Security Research of Tesla Autopilot. Retrieved February 14, 2024 from https://keenlab.tencent.com/en/whitepapers/Experimental_Security_Research_of_Tesla_Autopilot.pdf
- [31] Keen Security Lab. 2020. Exploiting Wi-Fi Stack on Tesla Model S. Retrieved February 14, 2024 from <https://keenlab.tencent.com/en/2020/01/02/exploiting-wifi-stack-on-tesla-model-s/>
- [32] Loren Kohnfelder and Praerit Garg. 2009. The STRIDE Threat Model. Retrieved February 14, 2024 from [https://docs.microsoft.com/en-us/previous-versions/commerce-server/ee823878\(v=cs.20\)](https://docs.microsoft.com/en-us/previous-versions/commerce-server/ee823878(v=cs.20))
- [33] Karl Koscher, Alexei Czeskis, Franziska Roesner, Shwetak Patel, Tadayoshi Kohno, Stephen Checkoway, Damon McCoy, Brian Kantor, Danny Anderson, Hovav Shacham, and Stefan Savage. 2010. Experimental security analysis of a modern automobile. In *Proceedings of the 2010 IEEE Symposium on Security and Privacy*. IEEE, 447–462. <https://doi.org/10.1109/SP.2010.34>
- [34] John Leyden. 2018. Connected car data handover headache: There's no quick fix . . . and it's NOT just Land Rovers. *The Register*. Retrieved February 14, 2024 from https://www.theregister.com/2018/08/21/connected_car_data_handover_mess/
- [35] John Leyden. 2018. Shock Land Rover discovery: Sellers could meddle with connected cars if not unbound. *The Register*. Retrieved February 14, 2024 from https://www.theregister.com/2018/07/27/jaguar_land_rover_connected_car_privacy/
- [36] Feng Luo, Yifan Jiang, Zhaojing Zhang, Yi Ren, and Shuo Hou. 2021. Threat analysis and risk assessment for connected vehicles: A survey. *Security and Communication Networks* 2021 (2021), 1–19. <https://doi.org/10.1155/2021/1263820>
- [37] Georg Macher, Christoph Schmittner, Omar Veledar, and Eugen Brenner. 2020. ISO/SAE DIS 21434 automotive cybersecurity standard—In a nutshell. In *Computer Safety, Reliability, and Security. SAFECOMP 2020 Workshops*, António Casimiro, Frank Ortmeier, Erwin Schoitsch, Friedemann Bitsch, and Pedro Ferreira (Eds.). Springer eBook Collection, Vol. 12235. Springer International Publishing, Cham, 123–135. https://doi.org/10.1007/978-3-030-55583-2_9
- [38] Kevin Mahaffey. 2015. Hacking a Tesla Model S: What We Found and What We Learned. Retrieved February 14, 2024 from <https://blog.lookout.com/hacking-a-tesla>
- [39] Piergiuseppe Mallozzi, Patrizio Pelliccione, Alessia Knauss, Christian Berger, and Nassar Mohammadiha. 2019. Autonomous vehicles: State of the art, future trends, and challenges. In *Automotive Systems and Software Engineering*. Springer, Cham, 347–367. https://doi.org/10.1007/978-3-030-12157-0_16
- [40] Charlie Miller and Chris Valasek. 2013. Adventures in automotive networks and control units. *DEF CON 21* (2013), 260–264.
- [41] Charlie Miller and Chris Valasek. 2014. A survey of remote automotive attack surfaces. In *Proceedings of the 2014 Black Hat USA Conference*.
- [42] Charlie Miller and Chris Valasek. 2015. Remote exploitation of an unaltered passenger vehicle. In *Proceedings of the 2015 Black Hat USA Conference*.
- [43] Charlie Miller and Chris Valasek. 2016. CAN Message Injection. Retrieved February 14, 2024 from <https://dl.packetstormsecurity.net/papers/attack/remote-attack-surfaces.pdf>

- [44] Ashcon Mohseninia. 2019. Made My Old Merc Put on a Small Lights Show Using an Arduino. Retrieved February 14, 2024 from <https://github.com/rnd-ash/W203-canbus>
- [45] Victor Murray. 2019. Legal GNSS spoofing and its effects on autonomous vehicles. In *Proceedings of the 2019 Black Hat USA Conference*.
- [46] National Vulnerability Database. 2019. CVE-2019-14951. Retrieved February 14, 2024 from <https://nvd.nist.gov/vuln/detail/CVE-2019-14951>
- [47] Alfred Ng. 2019. Smart alarms left 3 million cars vulnerable to hackers who could turn off motors. *CNET*. Retrieved February 14, 2024 from <https://www.cnet.com/news/privacy/smart-alarms-left-3m-cars-vulnerable-to-hackers-who-could-turn-off-motors/>
- [48] Sen Nie, Ling Liu, Yuefeng Du, and Wenkai Zhang. 2018. Over-the-Air: How we remotely compromised the gateway, BCM, and autopilot ECUs of Tesla cars. In *Proceedings of the 2018 Black Hat USA Conference*.
- [49] Samir Ouchani and Abdelaziz Khaled. 2019. A meta language for cyber-physical systems and threats: Application on autonomous vehicle. In *Proceedings of the 2019 IEEE/ACS 16th International Conference on Computer Systems and Applications (AICCSA'19)*. 1–8.
- [50] Nicolas Papernot, Patrick McDaniel, Ian Goodfellow, Somesh Jha, Z. Berkay Celik, and Ananthram Swami. 2017. Practical black-box attacks against machine learning. In *Proceedings of the 2017 ACM on Asia Conference on Computer and Communications Security*. 506–519. <https://doi.org/10.1145/3052973.3053009>
- [51] Irdin Pekaric, Clemens Sauerwein, Stefan Haselwanter, and Michael Felderer. 2021. A taxonomy of attack mechanisms in the automotive domain. *Computer Standards & Interfaces* 78 (2021), 103539.
- [52] Jonathan Petit, Bas Stottelaar, Michael Feiri, and Frank Kargl. 2015. Remote attacks on automated vehicles sensors: Experiments on camera and LiDAR. In *Proceedings of the 2015 Black Hat Europe Conference*.
- [53] Daniel Rekawek. 2019. How I hacked Volkswagen and Skoda. A story about Volkswagen Group Car Remote Hacking. *Vensis Cyber Security*. Retrieved February 14, 2024 from <https://blog.vensis.pl/2019/11/vw-hacking/>
- [54] Martin Ring, Jürgen Dürrwang, Florian Sommer, and Reiner Kriesten. 2015. Survey on vehicular attacks—Building a vulnerability database. In *Proceedings of the 2015 IEEE International Conference on Vehicular Electronics and Safety (ICVES'15)*. IEEE, 208–212. <https://doi.org/10.1109/ICVES.2015.7396919>
- [55] Marc Ruef. 2018. Daimler Mercedes Me App 2.11.0-846 on iOS Certificate Pinning Information Disclosure. Retrieved February 14, 2024 from <https://vulldb.com/?id.125081>
- [56] Marcel Rumez, Daniel Grimm, Reiner Kriesten, and Eric Sax. 2020. An overview of automotive service-oriented architectures and implications for security countermeasures. *IEEE Access* 8 (2020), 221852–221870.
- [57] Kai Rüsberg. 2015. Keyless Gone: Autodiebe Tricksen Kontaktlose Schließsysteme aus. Retrieved February 14, 2024 from <https://www.heise.de/select/ct/archiv/2015/26/seite-80>
- [58] SAE Vehicle Electrical System Security Committee. 2016. *SAE J3061: Cybersecurity Guidebook for Cyber-Physical Automotive Systems*. SAE.
- [59] Kai Schramm, Kerstin Lemke, and Christof Paar. 2006. Embedded cryptography: Side channel attacks. In *Embedded Security in Cars*. Springer, 187–206.
- [60] Florian Sommer and Jürgen Dürrwang. 2019. IEEM-HsKA/AAD: Automotive Attack Database (AAD) V3.0. Retrieved February 14, 2024 from [https://github.com/IEEM-HsKA/AAD/blob/master/Automotive_Attack_Database_\(AAD\)_V3.0.db](https://github.com/IEEM-HsKA/AAD/blob/master/Automotive_Attack_Database_(AAD)_V3.0.db)
- [61] Florian Sommer, Jürgen Dürrwang, and Reiner Kriesten. 2019. Survey and classification of automotive security attacks. *Information* 10, 4 (2019), 148.
- [62] Florian Sommer and Reiner Kriesten. 2022. Attack path generation based on attack and penetration testing knowledge. In *Proceedings of the 7th International Conference on Cyber-Technologies and Cyber-Systems*. 36–41.
- [63] Vangelis Stykas. 2018. Remote smart car hacking with just a phone. *Medium*. Retrieved February 14, 2024 from <https://medium.com/@evstykas/remote-smart-car-hacking-with-just-a-phone-2fe7ca682162>
- [64] Vangelis Stykas. 2019. Lojack'd: Pwning smart vehicle trackers. *Pen Test Partners*. Retrieved February 14, 2024 from <https://www.pentestpartners.com/security-blog/lojackd-pwning-smart-vehicle-trackers/>
- [65] The MITRE Corporation. 2022. Common Attack Pattern Enumeration and Classification (CAPEC). Retrieved February 14, 2024 from <https://capec.mitre.org/index.html>
- [66] The MITRE Corporation. 2022. Common Weakness Enumeration (CWE). Retrieved February 14, 2024 from <https://cwe.mitre.org/>
- [67] The MITRE Corporation. 2022. MITRE ATT&CK®. Retrieved February 14, 2024 from <https://attack.mitre.org/>
- [68] Vrizlynn L. L. Thing and Jiayi Wu. 2016. Autonomous vehicle security: A taxonomy of attacks and defences. In *Proceedings of the 2016 IEEE International Conference on Internet of Things (iThings), IEEE Green Computing and Communications (GreenCom), IEEE Cyber, Physical, and Social Computing (CPSCom), and IEEE Smart Data (SmartData)*. 164–170.

- [69] UNECE. 2021. UN Regulation No. 155—Uniform Provisions Concerning the Approval of Vehicles with Regards to Cyber Security and Cyber Security Management System: E/ECE/TRANS/505/Rev.3/Add.154. Retrieved February 14, 2024 from <https://unece.org/sites/default/files/2021-03/R155e.pdf>
- [70] UNECE. 2021. UN Regulation No. 156—Software Update and Software Update Management System: E/ECE/TRANS/505/Rev.3/Add.155. Retrieved February 14, 2024 from <https://unece.org/sites/default/files/2021-03/R156e.pdf>
- [71] Colin Urquhart, Xavier Bellekens, Christos Tachtatzis, Robert Atkinson, Hanan Hindy, and Amar Seeam. 2019. Cyber-security internals of a Skoda Octavia vRS: A hands on approach. *IEEE Access* 7 (2019), 146057–146069.
- [72] Roel Verdult, Flavio D. Garcia, and Baris Ege. 2013. Dismantling Megamos Crypto: Wirelessly lockpicking a vehicle immobilizer. In *Proceedings of the USENIX Security Symposium*. 703–718.
- [73] WMC. 2018. Used cars increase identity theft chances, BBB finds. *Action News*. Retrieved February 14, 2024 from <https://www.actionnews5.com/story/39022826/used-cars-increase-identity-theft-chances-bbb-finds/>
- [74] Working Party on Automated/Autonomous and Connected Vehicles. 2020. Proposals for Interpretation Documents for UN Regulation No. 155 (Cyber Security and Cyber Security Management System). Retrieved February 14, 2024 from https://unece.org/sites/default/files/2021-02/ECE-TRANS-WP29-2021-059e_0.pdf
- [75] Lennert Wouters, Eduard Marin, Tomer Ashur, Benedikt Gierlichs, and Bart Preneel. 2019. Fast furious and insecure: Passive keyless entry and start systems in modern supercars. *IACR Transactions on Cryptographic Hardware and Embedded Systems* 2019, 3 (2019), 66–85. <https://doi.org/10.13154/tches.v2019.i3.66-85>
- [76] Gongjun Yan, Danda B. Rawat, and Bhed B. Bista. 2012. Towards secure vehicular clouds. In *Proceedings of the 2012 6th International Conference on Complex, Intelligent, and Software Intensive Systems*. 370–375.
- [77] Xiaohong Yuan, Emmanuel Borkor Nuakoh, Jodria S. Beal, and Huiming Yu. 2014. Retrieving relevant CAPEC attack patterns for secure software development. In *Proceedings of the 9th Annual Cyber and Information Security Research Conference (CISR'14)*. ACM, 33–36. <https://doi.org/10.1145/2602087.2602092>
- [78] Daniel Zelle, Christian Plappert, Roland Rieke, Dirk Scheuermann, and Christoph Krauß. 2022. ThreatSurf: A method for automated Threat Surface assessment in automotive cybersecurity engineering. *Microprocessors and Microsystems* 90 (2022), 104461. <https://doi.org/10.1016/j.micpro.2022.104461>

Received 26 January 2023; accepted 20 January 2024